

КАРТОГРАФИЧЕСКОЕ ИССЛЕДОВАНИЕ BLOCKCHAIN-ТРАНЗАКЦИЙ И СМАРТ-КОНТРАКТОВ КИБЕРПРЕСТУПНИКОВ, АТАКУЮЩИХ АВТОМАТИЗИРОВАННЫЕ ИНФОРМАЦИОННЫЕ СИСТЕМЫ, И ОЦЕНКА УЩЕРБОВ ОТ РЕАЛИЗАЦИИ ИХ АТАК

А.Л. Сердечный, Д.А. Скогорева, Е.П. Длинный, Т.Ч. Ле, Д.В. Чьеу

Целью настоящих исследований следует считать противодействие компьютерной преступности за счёт совершенствования методов анализа их финансовых транзакций, осуществляемых в рамках операций с криптовалютами, построенными по технологии Blockchain. В рамках исследований разработана программная система сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах, а также разработана методика её применения для решения задач, связанных с противодействием компьютерной преступности. На примере анализа деятельности криптовымогателей показана возможность использования методики для оценки рисков, связанных с соответствующими угрозами. На основании полученных оценок были разработаны рекомендации по снижению рисков от угроз воздействия криптовымогателей. Полученные результаты могут быть применены для противодействия компьютерным преступлениям на корпоративные информационные системы, а также для оценки рисков реализации других угроз, связанных с группировками, использующими криптовалюты для осуществления своей преступной деятельности.

Ключевые слова: картографический метод, Blockchain, смарт-контракты, Bitcoin, криптовымогатели, риск, ущерб.

Введение

В современном информационном пространстве постоянно появляются новые технологии, которые существенно влияют на общественные отношения, в том числе деятельность киберпреступных группировок. Так, в 2009 году Сатоши Накамото было предложено децентрализованное одноранговое устройство системы электронных денег, названное Blockchain [1]. Прошло уже больше десяти лет, но оно все также остается актуальным и до конца неизученным.

Blockchain все больше привлекает внимание исследователей в различных областях знаний и дисциплинах, включая информационную картографию [2-10]. Детализированный и общедоступный характер набора данных Blockchain предоставляет уникальную возможность для изучения замкнутой системы в таком масштабе.

Мир киберпреступности не стоит на месте. Мошенники, вымогатели и другие киберпреступники находят новые способы

осуществления незаконной деятельности. Эффективным решением, обеспечивающим анонимность переводов выкупов с жертв, покупки нелегальных товаров, финансирования терроризма и отмывания денег является технология Blockchain.

Если раньше киберпреступникам для получения вознаграждения за совершение противоправных действий приходилось вступать в физический контакт с «заказчиком», то с появлением технологии Blockchain возникла инфраструктура криптовалют, позволившая преступности выйти на новый уровень. Данный инструмент даёт злоумышленникам возможность скрытного осуществления финансовых транзакций, что позволяет организовывать по-настоящему глобальные анонимные киберпреступные сообщества.

Особенно опасными подобные киберпреступные группы являются для корпоративных информационных систем. В последнее время такая деятельность стала носить массовый характер и наносить ущерб целым государствам, останавливая

деятельность региональных и транснациональных корпораций [2-4].

Основной **целью** исследования следует считать противодействие угрозам злоумышленников, которые используют криптовалюты для обеспечения своей деятельности в глобальном информационном сообществе сети Blockchain, за счёт разработки технического средства сбора сведений о Bitcoin-транзакциях и смарт-контрактах, выработки технологии построения и исследования информационных карт криптовалют, создания соответствующего методического обеспечения оценки рисков от деятельности киберпреступников, а также разработки рекомендаций по снижению таких рисков.

Для достижения сформулированной цели в рамках проведённых исследований были решены следующие **задачи**:

- разработана системы сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах с целью противодействия компьютерным преступлениям;

- разработана методика построения и анализа карт Blockchain-транзакций и смарт-контрактов для выявления шаблонов поведения киберпреступников, использующих криптовалюты;

- разработана методика количественного расчёта ущерба и оценки риска реализации компьютерных атак;

- предложены меры противодействия угрозам реализации компьютерных атак на корпоративные автоматизированные системы со стороны киберпреступников, использующих технологию Blockchain для обеспечения своей деятельности.

Из-за высокого уровня развития инфокоммуникационных технологий и оперативной доступности результатов научных исследований [5-16] существует проблема анализа большого объёма узкоспециализированной, а, иногда, и противоречивой информации, что препятствует пониманию общей научной картины.

Наиболее близкими к рассматриваемому подходу исследованиями являются работы [5-13], в которых авторы применили различные способы укладки и визуального

представления графа транзакций пользователей Blockchain-сети. Но ни в одном из этих исследований построенный граф нельзя назвать полноценной информационной картой, так как авторы данных работ используют функции визуального представления графа, заложенные по умолчанию в программные средства, не обосновывая эффективность и полезность данного метода.

В ходе анализа научных публикаций по теме исследований была отмечена особенность, выражающаяся в том, что ни в одной из работ не использовалась технология создания и исследования карты Blockchain-транзакций и смарт-контрактов, которая облегчает процесс моделирования и отображения пространственного расположения, сочетания и взаимосвязи объектов, явлений, происходящих в Blockchain. Кроме того, отсутствуют исследования киберпреступных группировок, которые используют одновременно обе технологии.

Аппарат решения научных задач исследования, отличается от известных аналогов учётом возможности анализа смарт-контрактов совместно с Bitcoin-транзакциями, что является важным аспектом при расследовании преступной деятельности злоумышленников, так как некоторые киберпреступные группировки используют эти две технологии для смешивания и запутывания своих действий, препятствуя расследованию. Совместный анализ технологий Bitcoin-транзакций и смарт-контрактов позволяет улучшить техники анализа и получать дополнительные сведения.

В сравнении с аналогами, разработанная система сбора и картографического анализа сведений о Blockchain -транзакциях и смарт-контрактах отличаются структурой и составом, а также имеет широкие возможности визуального анализа Blockchain-транзакций, высокую скорость сбора сведений о Bitcoin-транзакциях и смарт-контрактах, работает даже на низкопрофильных устройствах. Также преимуществом является высокая скорость обработки полученных данных, а также извлечение и сохранение файлов

непосредственно в базе данных, что не влияет на объем памяти устройства.

Методика построения и анализа карт Bitcoin-транзакций и смарт-контрактов также имеет ряд преимуществ по сравнению с аналогичными работами. В данной работе присутствуют примеры визуализации предложенной методики, что делает ее доказанной и эффективной. Состав методов визуализации и анализа графа транзакций, применяемых в методике, отличается от аналогов возможностью экспертного исследования большого объема данных о Bitcoin-транзакциях и смарт-контрактах, а также позволяет выявить шаблоны поведения киберпреступных групп.

В сравнении с аналогами подход и методика количественной оценки риска и ущерба от реализации киберпреступлений на корпоративные информационные системы с помощью анонимной сети Blockchain, представленные в настоящей работе, являются практически единственным решением по оценке риска и ущерба совместно.

Картографическое исследование – как один из возможных методов преодоления данных противоречий за счёт использования возможностей экспертов по анализу

визуальной информации. Если данные о Blockchain-транзакциях и смарт-контрактах представить определённым образом, то эксперт может на основании своего опыта и способности мозга анализировать графическую информацию выявлять сложные взаимосвязи и устанавливать причинно-следственные связи между компьютерными преступлениями и оплатой посредством использования криптовалют.

Основные аспекты технологии Blockchain и смарт-контрактов

Blockchain является эффективной особой платформой для совершения транзакций в рамках сети, объединяющей равноправных участников, действующих без посредников. В Blockchain применяется децентрализованное хранение информации для отражения всех данных об операциях, это значит, что записи о транзакциях хранятся в общедоступном, незашифрованном виде с указанием адресов отправителей и получателей, но информация о реальных владельцах этих адресов не предусмотрена [1].

Массовое распространение эта технология получила благодаря понятным и простым правилам своего построения, принципов, которые изображены на рис. 1.

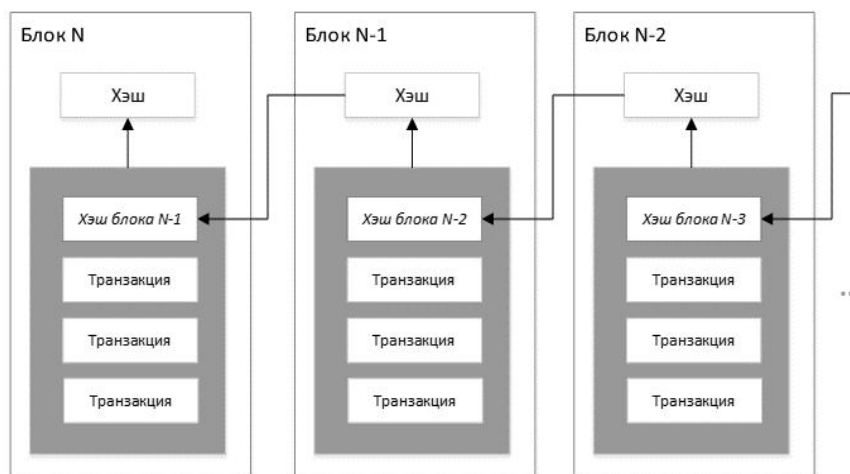


Рис. 1. Основные принципы взаимодействия в сети Blockchain

Основное движение в такой системе происходит с помощью транзакций. Во время транзакции может выполняться какой-то скрипт, либо прописываться некая заметка с данными. То есть слово «транзакция» не равно денежному переводу и скорее обозначает способ обработки информации внутри сети.

Новизна технологии «Blockchain» выражена в том, что информация о произведенных транзакциях больше не хранится в централизованной базе данных, а передается на компьютеры всех участников сети (ноды), которые хранят данные на своих машинах.

Подытожив вышесказанное, можно отметить, что Blockchain является

децентрализованной БД, в которой все транзакции (записи) собираются в блоки и связываются между собой средствами криптографии. В блок включаются хеш-суммы текущего и предыдущего блоков, помимо самих записей и идентификатора блока. Хеш-суммы представляют собой результат вычисления криптографических хеш-функций. Именно эти хеш-функции в Blockchain, в сочетании с его распределенной архитектурой, обеспечивают неизменность и необратимость всей цепочки блоков и транзакций.

Узлы в Blockchain синхронизируются между собой посредством одноранговой пиринговой сети. Безопасность этой сети полагается первый алгоритм консенсуса - принцип доказательства выполнения работы (proof of work), который реализуется с помощью майнинга блоков.

Доказательство выполнения работы (proof of work) – принцип защиты распределенных систем от злоупотреблений, таких как DoS-атака или организация рассылок спама, суть которого выражается в необходимости выполнения определенной длительной работы (нахождение решения задачи) на стороне клиента, и быстрой проверкой результата на стороне сервера. Задачи изначально ориентированы на нахождение компьютером решения по определенному алгоритму за некоторое время, зависящее от вычислительной мощности компьютера.

Механизм Proof of Work открыл миру новый способ заработка – майнинг, то есть получение вознаграждения в виде криптоактива за создание блока. Вероятность успешного создания следующего блока майнером зависит от вычислительной мощности, которой он обладает, что приводит к постоянному наращиванию количества и качества ресурсов каждого участника сети, что с одной стороны делает атаку на Blockchain непомерно дорогостоящей, а с другой – делает POW подход экологически недружелюбным, так как применение этой технологии требует чрезвычайно много электроэнергии.

Из-за децентрализованности сети и криптографических механизмов, рассмотренных выше, злоумышленникам все сложнее осуществлять противоправные деяния с информацией, так как они становятся дорогостоящими и затруднительными.

Однако традиционная модель децентрализованной публичной Blockchain - сети, обеспечивающей прозрачность и устойчивость к цензуре, в силу своей архитектуры и идеологии не позволяет обеспечить третий аспект ИБ – конфиденциальность данных. Именно поэтому система уязвима для проведения атак и интересна для проведения исследования.

С помощью распределенного реестра, асимметричного шифрования, интеллектуального контракта, механизма консенсуса и других базовых технологий Blockchain обеспечивает для пользователей сети двухточечную анонимность, отслеживаемость, защиту от несанкционированного доступа, а также гарантирует безопасность нахождения в системе и предлагает решение проблемы доверия.

История Blockchain, как популярного технического явления, началась благодаря криптовалюте Bitcoin. Важно заметить, что финансовые активы всегда привлекают внимание злоумышленников, и публичный Blockchain всегда подвергается различным атакам.

Транзакция в системе «Blockchain» создается текущим владельцем, в которой указываются данные не только о количестве передаваемых Bitcoin, но и публичный ключ и подписанный хеш предыдущей транзакции, из которой Bitcoin были получены владельцем. Эта предыдущая транзакция будет «входом» для новой транзакции. «Выходом» новой транзакции будет являться Bitcoin-адрес получателя в транзакции. Схематический пример множественных входов и выходов транзакции изображен на рис. 2.

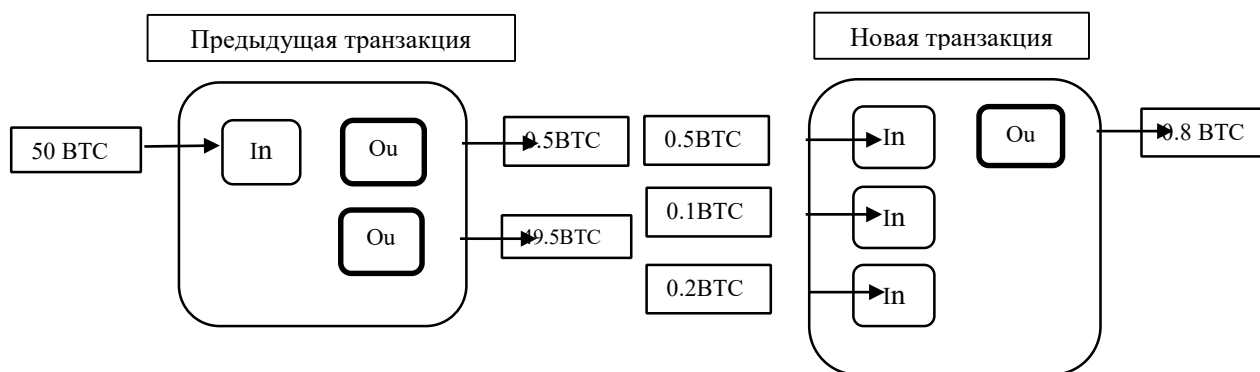


Рис. 2. Схематическое представление множественных входов и выходов в транзакциях криптовалюты Bitcoin

Остальные узлы в системе проверяют, действительно ли субъект является владельцем приватного ключа для адреса выхода.

Если подробнее говорить о блоках транзакций, то можно отметить, что первая транзакция всегда формируется автоматически и передает вознаграждение за создание блока. Все остальные транзакции берутся майнерами из очереди транзакций, причем приоритетными для майнера являются транзакции, имеющие комиссию [1, 15, 17, 18].

Необходимо отметить систему сложных взаимоотношений в рамках обмена криптовалютами, а также разновидности участников финансового обмена. Основные структурные элементами являются:

- майнеры;
- майнинг-пулы;
- криптобиржи;
- «миксеры».

Их структура и выявление будут отмечены далее.

Криптовалюты – это не единственное применение технологии Blockchain. Второй ступенью в развитии данной технологии стали умные контракты. Умные контракты помогают избежать посредничества в финансовых вопросах путем выполнения программного алгоритма, предназначенного для самостоятельного исполнения действия при наступлении определенных условий и находящегося в цепочке блоков. Стороны контракта подписывают смарт-контракт методами, аналогичными подписи транзакций, и размещают по определенному адресу в Blockchain.

Смарт-контракты – это компьютерный алгоритм, в котором полностью прописаны предмет и условия «сделки», а также порядок исполнения данных условий в полностью автоматическом режиме без участия третьей стороны (банка, нотариуса, государства, свидетеля и т.п.). Смарт-контракт является компьютерной программой, связанной с транзакцией, которая определяет условия совершения сделки в результате её выполнения специальным программным обеспечением, функционирующим в рамках криптовалютной платформы [17].

Технология смарт-контрактов активно развивается в рамках криптовалюты платформы Ethereum. Эта платформа позволяет создавать децентрализованные проекты на Blockchain, начиная от благотворительных фондов, и завершая приложениями для ставок на спорт или покерными румами. При этом платформа открыта так, что доступ к ней может получить каждый.

Десятки тысяч компьютерных приложений, написанных на разных языках программирования, теперь могут взаимодействовать между собой на одной площадке, что значительно расширило область применения технологии Blockchain. По словам Виталика Бутерина, - создателя данной криптовалюты: Ethereum - это новый Blockchain со всеми его возможностями и неограниченными перспективами.

Примером самого простого контракта в Ethereum является мультиподпись – схема реализации подписания транзакций несколькими приватными ключами для повышения уровня безопасности и

конфиденциальности в процессе одобрения отправки транзакций.

Смарт-контракты могут быть разработаны для широкого спектра вариантов использования. Например, создание токенизированных активов, систем голосования, криптовалютных кошельков, децентрализованных бирж, игр и мобильных приложений.

Токен – это единица учета, которая используется для представления цифрового баланса в некотором активе. Следовательно, токенизация – это процесс трансформации учета и управления активами, при котором каждый актив представляется в виде цифрового токена. Суть токенизации – в создании цифровых аналогов для реальных ценностей с целью быстрой и безопасной работы с ними. В последнее время одним из наиболее распространенных методов привлечения средств на запуск и развитие проектов в криптовалютном сообществе стали так называемые первоначальные размещения токенов (ICO). Чаще всего это токены на протоколе ERC-20.

Несмотря на целый ряд преимуществ и огромную сферу применения, Ethereum все еще не смог обойти Bitcoin по популярности и активности пользователей [17].

Обзор известных результатов исследований технологии Blockchain как инструмента киберпреступной деятельности

Анализ научного пространства по теме исследований был осуществлен с помощью интерактивной карты, разработанной в рамках настоящих исследований, в соответствии с технологией, описанной в [19]. Информационная карта поиска научных публикаций представляет собой интерактивную панель, включающую:

- изображение генеральной карты публикаций с разграниченными тематическими областями;
- столбчатую диаграмму, отображающую количество публикаций в соответствующих научных журналах;
- таблицы идентификаторов авторов и названий научных публикаций;
- линейный график распределения научных публикаций по годам;

- индикаторы количества кластеров, публикаций и авторов.

Количество работ по близким к теме исследований областям представлено в табл. 1.

На построенной карте чётко прослеживаются основные основные темы:

- визуальный анализ Bitcoin-транзакций, попытки проведения полноценного картографического исследования;
- применение технологии Blockchain злоумышленниками для осуществления своей киберпреступной деятельности;
- визуальное представление технологии смарт-контрактов;
- технические средства для сбора данных о Bitcoin-транзакциях;
- технические средства для сбора данных о смарт-контрактах;
- методики количественной оценки риска и ущерба от реализации киберпреступлений с использованием Bitcoin-транзакций и смарт-контрактов на автоматизированные информационные системы.

Таблица 1

Тематические области и количество статей

Тематическая область	Количество статей
Графовый анализ Blockchain	54
Визуальный анализ Bitcoin-транзакций	145
Анализ графа транзакций Bitcoin	43
Выявление криминальных финансовых потоков на графе Bitcoin-транзакций	73
Blockchain и преступность	55
Визуальное представление Ethereum	15
Ущерб от реализации компьютерных атак	15
Количественный анализ рисков	6
Качественный анализ рисков	9
Применение Python для анализа blockchain - транзакций	2

Рассмотрение существующих аналогов приводится ниже.

Визуальный анализ Bitcoin-транзакций, попытки проведения полноценного картографического исследования

Наиболее близкими к рассматриваемой теме исследования являются работы [5-13], в которых авторы применили различные

способы укладки и визуального представления графа транзакций пользователей Blockchain-сети. Но ни в одном из этих исследований построенный граф нельзя назвать полноценной картой, так как авторы данных работ используют функции визуального представления графа, заложенные по умолчанию в программные средства, не обосновывая эффективность и полезность данного метода.

В работе [5] было разработано средство анализа сети Blockchain, которое объединяет адреса в кластеры, классифицирует и маркирует такие объекты, таким образом в исследовании проводится попытка деанонимизации преступных группировок. Несмотря на озвученные преимущества данного исследования, в нем нет одного важного аспекта – примеров визуализации предложенной технологии.

Применение Blockchain для осуществления киберпреступной деятельности

Попытка поиска подозрительных транзакций, связанных с преступной деятельностью злоумышленников, была предпринята в исследованиях [12, 13], в которых предлагались способы вычисления сделок преступных группировок различными методами, но исследователи смогли только теоретически обосновать полезность своих средств, не применяя их на практике, что создает сомнения в эффективности предложенных методик.

Интерес вызывает работа, написанная в 2015 году [12], в которой используется аналогичная структура расследования киберпреступлений с использованием технологии Bitcoin, а именно: разработка и применение средства сбора информации о Blockchain-транзакциях за определенный промежуток времени, кластеризация адресов, построение графа транзакций и использование вышеуказанных этапов на практике с нашедшим случаем кражи Bitcoin с криптобиржи Mt. Gox в 2014 году. Отличительной особенностью исследования, проводимого в данной работе, является быстрое и легкое адаптирование технического средства под разные временные промежутки, понятная и структурированная

технология построения и графового анализа карт не только Bitcoin-транзакций, но и смарт-контрактов, а также создание методики количественной оценки риска и ущерба от реализации киберпреступной деятельности.

В работе [11] раскрываются 6 схем использования криптобирж киберпреступниками для вывода средств, а также технологии их выявления, что рассматривается как посыл к бездействующему законодательству. Это является хорошим детализированным анализом узкой темы, но не полноценным картографическим исследованием.

Визуальное представление Ethereum

В [6] проводился эксперимент применения существующих методов исследования Bitcoin-транзакций к смарт-контрактам, происходящим в Ethereum. Это практически единственное исследование, в котором рассматривались смарт-контракты как объект для осуществления деяний злоумышленников.

Технические средства для сбора и анализа данных о Blockchain-транзакциях

Значительное количество работ по теме анализа цепочки Bitcoin полагается на пользовательский граф, который можно построить с помощью эвристики для кластеризации адресов Bitcoin. Следуя этому подходу, в [20] объясняют, почему эвристика с несколькими входами эффективна. В отличие от вышеупомянутых работ, [21] используют данные вне сети в дополнение к эвристике на основе Blockchain для кластеризации. Более того, Чанг и Светинович комбинируют хорошо известные эвристики (т.е. эвристику с несколькими входами и эвристику изменений) с эвристикой, основанной на шаблонах транзакций, описанных в [22].

В последние годы в области анализа Blockchain были разработаны инструменты для анализа адресов Blockchain и кластеров Bitcoin. Reid и Harrigan [22] в 2011 г. Также Meiklejohn et al. в 2013 году использовали собственные модифицированные версии библиотеки Python bitcointools, разработанной Гэвином Андерсоном для анализа Blockchain. Однако эти подходы

включали ручные действия, такие как маркировка кластеров адресов. Таким образом, Spagnuolo et al. в [13] представили BitIodine, который автоматически анализирует цепочку блоков, объединяет адреса в кластеры, классифицирует адреса и пользователей, строит графики, экспортирует и визуализирует информацию из сети Bitcoin. Они используют модифицированную версию анализатора блоков Znort987 C++ по соображениям производительности и для простоты хранят данные цепочки блоков во встроенной базе данных SQLite. Для кластеризации адресов в соответствии с эвристикой множественного входа и эвристикой теневого адреса они используют NetworkX-библиотеку Python для сложных сетей.

Еще одной областью интересов, в которой используются преимущества анализа Blockchain, были экономические исследования. Мозер и Боме [30] сосредоточили внимание на комиссиях за транзакции Bitcoin и попытались определить поведение агентов путем анализа их комиссий за транзакции, используя общедоступные записи Blockchain о Bitcoin и обменные курсы от Coindesk провели анализ рынка с использованием Blockchain, объединив сетевые данные и географические местоположения, чтобы получить представление о распределении криптовалютного бизнеса с течением времени. В обоих исследованиях использовался blockexplorer.com - веб-инструмент с открытым исходным кодом, который позволяет визуализировать информацию о блоках и транзакциях Blockchain в качестве основного источника данных.

Другие области анализа цепочки блоков включают изучение языка сценариев, используемого протоколами криптовалюты. Бартолетти использовал аналитику цепочки блоков и разработал инструмент под названием OpReturnTool [31] для исследования метаданных, связанных с инструкцией OP_RETURN, командой, которая включена в Bitcoin и обеспечивает способ встраивания дополнительных данных в цепочку блоков. Он настроен на разрешение до 80 байтов данных, и, когда транзакция,

содержащая поле OP_RETURN, подтверждается майнингом, это содержимое будет добавлено в блок и, следовательно, останется в цепочке блоков навсегда. Это инструмент, который может облегчить изучение недостатков Bitcoin с помощью визуализации цепочки блоков.

Blockchain.info - один из самых популярных и часто используемых аналитических инструментов Blockchain, который впервые появился на рынке еще в 2011 году. Применение эвристики кластеризации к данным, предоставленным blockchain.info и информации, доступной на публичном Bitcoin-форуме, помогает классифицировать ряд транзакций в пользовательской сети и выполнить анализ трафика по движению денег [54].

Технические средства для сбора данных о смарт-контрактах

Существует несколько фреймворков для извлечения данных из Blockchain Ethereum. Однако большинство из них рассматривают только данные блока и вообще не могут использоваться для извлечения данных состояния.

Ethereum ETL (сокращение от extract, transform и load) - это сторонняя среда, предоставляющая простые в использовании сценарии для экспорта большого количества блоков, транзакций и токенов в файлы csv. Он написан на Python и использует фреймворк Web3.

Однако экспорт данных в файлы csv только для последующего импорта их в базу данных SQL кажется ненужным промежуточным шагом, который можно пропустить, напрямую добавив данные блока в базу данных.

В своей статье «New kids on the block: an analysis of modern blockchains» [23] Андерсон и др. разработали экстрактор данных Ethereum в NodeJS. Их реализация извлекает данные непосредственно из структуры данных Geth на диске и сохраняет их в базе данных PostgreSQL. Затем они используют эти данные для выполнения анализа безопасности смарт-контрактов и для генерации нескольких статистических данных, таких как продолжительность жизни самоуничтоженных контрактов. Однако

неясно, сможет ли эта реализация справиться с текущим размером Blockchain, поскольку документ датируется 2016 годом, и в работе извлекаются данные только до блока 1,358,548.

Обзор существующих методик количественной оценки риска и ущерба от реализации киберпреступлений с использованием Bitcoin-транзакций и смарт-контрактов на информационные системы

Многие существующие риски современных организаций возникают в киберпространстве, а их последствия могут оказывать непосредственное влияние на финансовую и операционную деятельность. При этом ущерб, связанный с атаками на корпоративные автоматизированные системы, исчисляется миллиардами долларов, поэтому модернизация средств расчетов ущерба и оценки ущерба, становится актуальной.

Практика «Делойта», представленная в статье [24], которая помогает компаниям улучшать бизнес процессы и качественнее внедрять новые технологии, основываясь на комплексном подходе к управлению кибер-рисками, помогает выстроить особый подход к информационной безопасности в организации.

Делойт предполагает разработку индивидуальной модели, позволяющей оценивать киберриски, в том числе в денежном выражении, а также влияет на отключение ключевых показателей деятельности организации от плановых значений. Для оценки кибер-рисков используются методы факторного и сценарного анализа и имитационного моделирования с учетом оценки.

В основном данный метод подходит для применения в банковских системах. Но такой подход мало применим к технологии Blockchain, даже учитывая тот факт, что есть определенные части, которые можно применить для рекомендательных мер.

Если рассматривать Bitcoin, как отдельную цифровую технологию,

существуют подходы к выделению уровней угрозы применения данной технологии. [25]. В данной работе предлагаются методы оценки риска использования «Bitcoin», путем процедуры, состоящей из нескольких пунктов.

Рассмотрение по этим пунктам позволяет дать степень оценки уровня риска к разным сферам от социальной, до экономической. Но данный способ, не позволяет детально и четко просчитать ущерб, в отличие от картографического метода, применяемого в настоящей работе [26-29].

Результаты разработки системы сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах

Картографическое исследование Blockchain-транзакций и смарт-контрактов осуществлялось с помощью разработанной системы анализа рисков и ущербов от киберпреступной деятельности, схема которой представлена на рис. 3. При её разработке был учтён опыт аналогичных исследований [13, 20-23, 30, 31, 54].

Система сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах включает:

- подсистему сбора сведений о Bitcoin-транзакциях;
- подсистему сбора сведений о смарт-контрактах;
- подсистему сбора сведений со сторонних информационных ресурсов (на основе плагина Web scraper);
- подсистемы визуализации и интерактивного анализа Blockchain-транзакций.

Подсистема сбора данных представляет собой программу, написанную на языке Python, которая осуществляется сбор сведений из информационных источников blockstream.info (содержит сведения о Bitcoin-транзакциях) и etherscan.io (содержит сведения о смарт-контрактах).

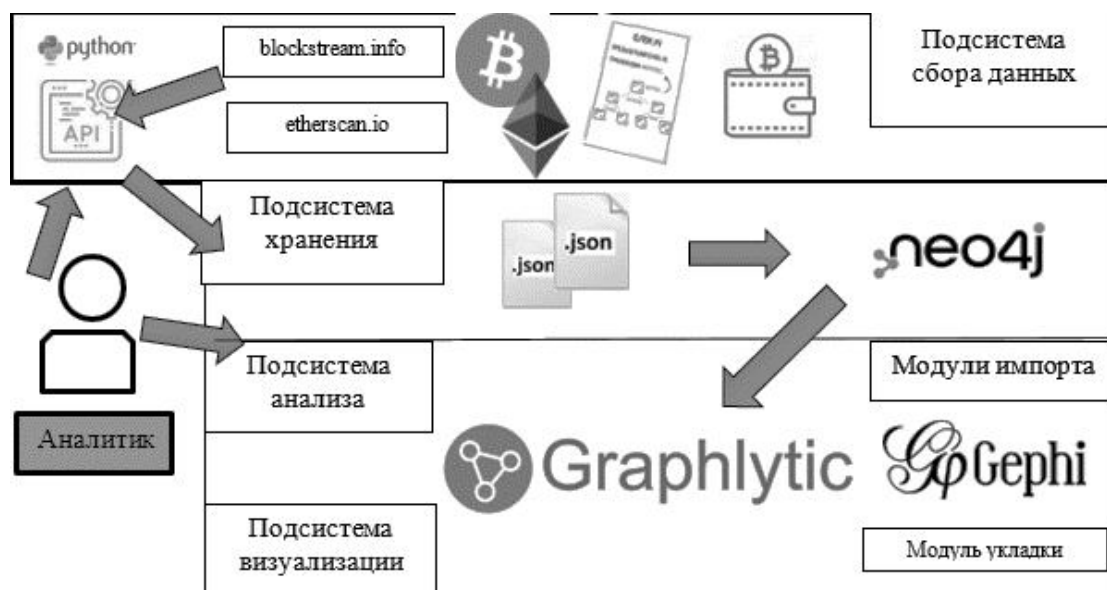


Рис. 3. Структурная схема системы сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах

Полученные сведения преобразуются к формату данных, определяемых графовыми моделями (рис. 4 и 5).

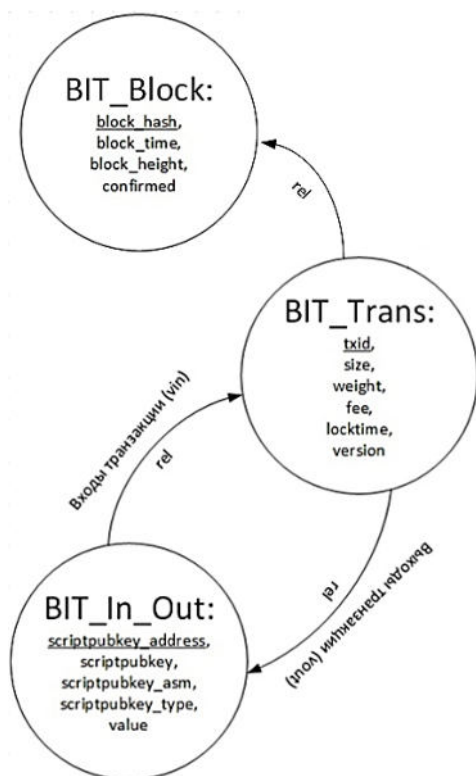


Рис. 4. Модель данных, используемая для хранения сведений о Bitcoin-транзакциях

Модель данных, используемая для хранения сведений о Bitcoin-транзакциях (рис. 4), включает следующие узлы:

- BIT_Block (блок цепочки Bitcoin-транзакций, идентифицируемый по уникальному хеш-значению);
- BIT_Trans (Bitcoin-транзакция, которую можно идентифицировать по ее уникальному значению txid);
- BIT_In_Out (адреса отправителей и получателей Bitcoin-транзакций, представляющие собой идентификаторы криптокошельков).

Эти узлы связаны следующими отношениями:

- BIT_Block $\leftarrow$ BIT_Trans (отношение определяет цепочку блоков, идущих друг за другом);
- BIT_Block $\leftarrow$ BIT_Trans (принадлежность транзакции блоку);
- BIT_Trans $\rightleftharpoons$ BIT_In_Out (отношения между криптокошельками отправителей и получателей).

Модель данных, используемая для хранения сведений о смарт-контракте Ethereum (рис. 5), соответствует структуре JSON-ответа источника etherscan.io, который имеет следующий формат:

- status (представляет статус запроса и принимает значение 1, если запрос данных о смарт-контрактах был успешным, 0 – в противном случае);

-blockNumber (номер блока, содержащего транзакцию или смарт-контракт);
 - timeStamp (время создания блока);
 - hash (идентификатор транзакции, которая может быть обычной транзакцией или смарт-контрактом, с которым сопоставлен некоторый код);
 - from (адрес криптокошелька отправителя, который может быть адресом кошелька учетной записи пользователя, который хочет совершить обычную транзакцию или создать смарт-контракт, а

являться адресом кошелька смарт-контракта, который создаёт или вызывает другой смарт-контракт);
 - to: (адрес кошелька получателя);
 - value (значение транзакции, выражающее передаваемую криптовалюту);
 - contractAddress (адрес кошелька смарт-контракта, по которому совершается транзакция: адрес будет пустым, если это обычная транзакция или учетная запись вызывает смарт-контракт);
 - type (тип совершенной транзакции).

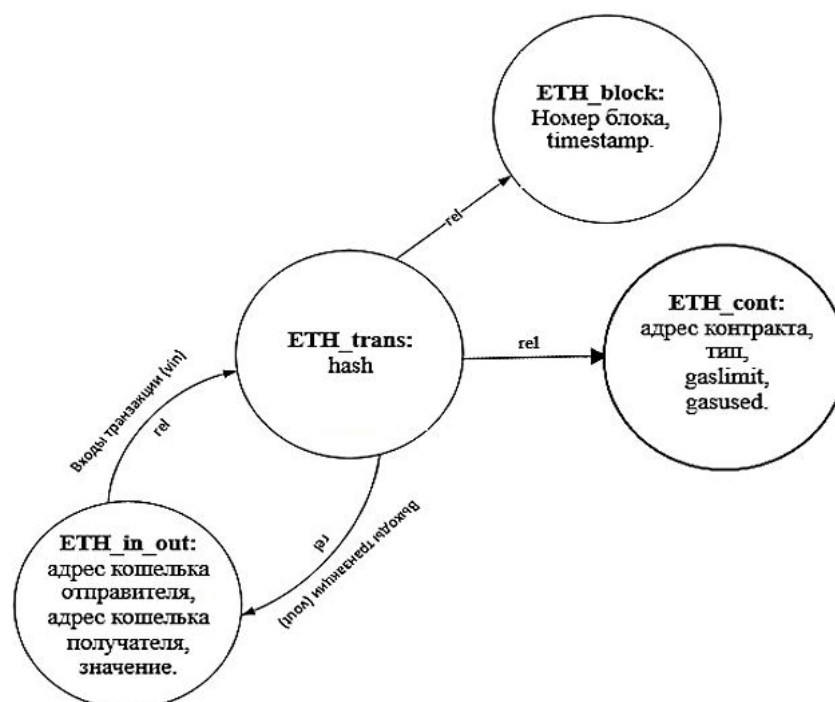


Рис. 5. Модель данных, используемая для хранения сведений о смарт-контракта Ethereum

Собранные сведения размещаются в базе данных Neo4j, которая является ядром системы сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах. Графовая база данных Neo4j была выбрана за её уникальные свойства хранения и обработки больших графов. Данная система управления базами данных (СУБД) свободно распространяется, хорошо документирована и имеет самый рейтинг среди графовых СУБД. Отдельно необходимо отметить язык запросов Neo4j Cypher, с помощью которого легко осуществлять доступ к хранящимся данным за счёт гибкости выбора параметров запросов.

В состав Neo4j также включён набор библиотек, реализующих операции анализа

графов (поиск по шаблонам, кластеризацию, расчёт метрик центральности и др.). В комбинации с Python-библиотеками они составляют подсистему анализа сведений о Bitcoin-транзакциях и смарт-контрактах, а также используются для построения информационных карт, о которых будет сказано далее.

Подсистема визуализации представлена двумя модулями:

- Gephi (общедоступная программа, написанная на языке Java, которая в рамках разработанной системы используется для визуализации и анализа больших и средних графов размером от 200 до 200 000 узлов с целью определения общего представления об участниках Blockchain-транзакций);

- Graphlytic (плагин к СУБД Neo4j, используемый для направленного визуального анализа конкретных цепочек Blockchain-транзакций киберпреступников).

Оценка характеристик системы сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах приводилась в ходе натурного эксперимента на персональном компьютере с параметрами, представленными в табл. 2.

Таблица 2

Характеристики аппаратного обеспечения, использованного для работы системы сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах

Компонент	Описание
Процессор	Intel Core™ i5-6500U
Память	8.00 ГБ
Диск	512 ГБ SSD

Для оценки подсистемы сбора сведений о Bitcoin-транзакциях было собрано 10 блоков (блоков с номерами от 679171 до 679180). Информация о собранных данных приведена в табл. 3.

Таблица 3

Статистика по количеству узлов и рёбер

Тип узлов	Количество
Блок	10
Транзакция	62938
Адрес	100428
Отношений	201169

Сбор данных был завершён в течение 8 минут и 31 секунды, а общий размер базы данных составил 113,7 МБ. Файлы сведений об отношениях между узлами составляют большую часть (62%) от общего размера базы. На рис. 6 представлено количество транзакций и скорость сбора.



Рис. 6. Количество транзакций и скорость сбора сведений о Blockchain-транзакциях

Для оценки подсистемы сбора сведений о смарт-контрактах были использованы два компьютера с различной конфигурацией (табл. 4).

Таблица 4

Конфигурации двух компьютеров, использованных для сбора сведений о Ethereum-транзакциях и смарт-контрактах

Компонент	Компьютер 1	Компьютер 2
Процессор	Intel Core™ i5-9300H	Intel Core™ i5-6500U
Память	DDR4 16 ГБ	DDR4 8 ГБ
Диск	256 ГБ SSD	512 ГБ SSD
Видеокарта	Nvidia 1650 max Q 4 ГБ	Intel UHD 630

Полученные результаты сравнения скорости сбора сведений о Ethereum-транзакциях и смарт-контрактах показаны на рис. 7.

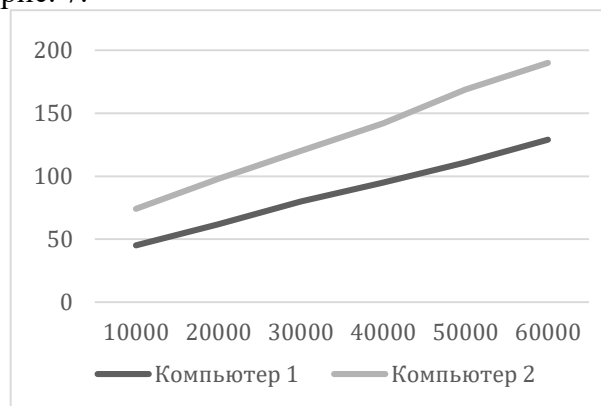


Рис. 7. Сравнение скоростью сбора сведений о Ethereum-транзакциях и смарт-контрактах

Методика отслеживания Bitcoin-транзакций и смарт-контрактов

Отслеживание Blockchain-транзакций и смарт-контрактов киберпреступников в контексте реализации атак на корпоративные информационные системы осуществляется в соответствии со схемой, представленной на рис. 8 [19].

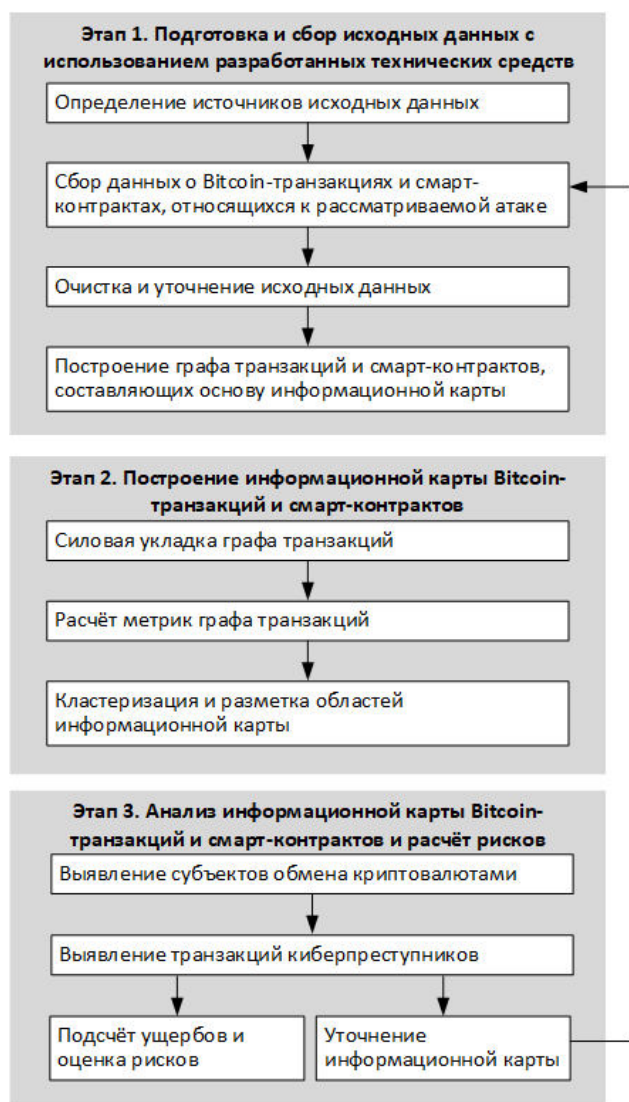


Рис. 8. Схема отслеживания Blockchain-транзакций и смарт-контрактов киберпреступников

На первом этапе проводится поиск предварительной информации, которая может иметь различную полноту. Так, например, при наличии сведений о конкретных адресах криптокошельков киберпреступников процедура анализа существенно упрощается, так становятся известны транзакции, связанные с этими адресами. Если имеются сведения только

лишь о временном периоде, за который была совершена атака (жертвой уплачен выкуп), требуется проведение анализа достаточно большого объема данных, которые могут включать миллионы транзакций. В этом случае решающим фактором становится наличие дополнительных сведений (например, о размере выкупа или типовом поведении киберпреступников).

Далее на основе предварительной информации с помощью системы сбора и картографического анализа осуществляется построение информационных карт для графа Blockchain-транзакций, найденных в соответствии с условиями поиска. Процедура построения информационной карты аналогична процедуре, описанной в [19] для графа соавторов научных публикаций. Её построение включало:

- очистку и уточнение исходных данных (фильтрация, уточнение, отбрасывание избыточных данных и другие подготовительные операции, связанные с графом Blockchain-транзакций);

- силовую укладку графа (определение расположения узлов графа в соответствии с алгоритмами, основанными на физических аналогиях; её особенностью является то, что наиболее связанные узлы окажутся расположенными ближе друг к другу, чем к узлам, с которыми они связаны в меньшей степени; данный тип укладки имеет ключевое значение при анализе Blockchain-транзакций, так как обеспечивает интуитивно понятную форму представления большого объема данных);

- расчет метрик графа (является важным шагом при проведении визуального анализа, так как позволяет отображать важные особенности анализируемых транзакций и криптокошельков; так, например, большой размер узла криптокошелька, определённый в соответствии со значением сумм криптовалюты, которая на нём размещена, может свидетельствовать о его принадлежности к криптобирже);

- кластеризация и разметка областей информационной карты (заключается в применении алгоритмов кластеризации графа Blockchain-транзакций с последующей ручной разметкой соответствующих областей информационной карты; это делается с целью

определения основных субъектов, проводящих операции с криптовалютой; знание принадлежности криптокошелька к определённой криптобирже или средствам защиты от отслеживания транзакций является важным звеном в цепочке расследований инцидентов, связанных деятельностью киберпреступников; результаты автоматической кластеризации позволяют распространять метки свойств на всю группу узлов, для которой соответствующее свойство является кластерообразующим, а экспертный визуальный анализ позволяет корректировать ошибки, которые неотвратимо будут появляться в связи с несовершенством автоматических алгоритмов).

На завершающем этапе проводится анализ размеченной информационной карты для достижения поставленных задач (например, определения размера ущерба от компьютерных атак, совершённых конкретной киберпреступной группировкой). В ходе анализа может быть установлено, что текущих исходных данных недостаточно и требуется уточнение информационной карты.

С целью выбора наиболее подходящего представления сети Blockchain и для её визуального анализа были разработаны эскизы интерактивной Blockchain-транзакций и смарт-контрактов, для которых проведён сравнительный анализ на основании следующих критериев:

- близости расположения наиболее связанных типовых структур, выявленных для сети Blockchain;
- учёта масштаба карты.

В соответствии с первым критерием наиболее связанные между собой криптокошельки должны располагаться на карте ближе друг к другу, чем к остальным криптокошелькам. Данный критерий задаёт основу для визуального выявления закономерностей организации данных структур. При выполнении данного критерия с определённой степенью допущения можно обобщать результаты, полученные для некоторых представителей из данной области, на всех локализованных в ней участников. Вторым критерием является требование к масштабу карты, определяемому количеством отображаемых

элементов. Для разных размеров отображаемых участков сети Blockchain должны использоваться свои способы построения, позволяющие сформировать такую карту, на которой будут показаны все необходимые элементы и, при этом, внимание эксперта не будет перегружено.

Построение и анализ карт мелкого и среднего масштабов (граф более 200 узлов) осуществляется с помощью программы Gephi, а сама карта используется для понимания оперативной обстановки на рынке криптовалют с целью сокращения области поиска транзакций, которые имеют непосредственное отношение к задачам исследования. Анализ конкретных цепочек транзакций (карт крупного масштаба) проводится с помощью средства Graphlytic.

В рамках настоящих исследований анализ информационных карт Blockchain-транзакций проводился для решения следующих задач:

- выявление состава и ролей участников рынка криптовалют;
- определение типовых шаблонов поведения злоумышленников;
- формирование правил написания запроса, позволяющего получить данные о транзакциях в соответствии с выявленными шаблонами поведения злоумышленника;
- определение ущерба и оценка риска от реализации киберпреступлений на корпоративные информационные системы.
- разработка и формулирование мер противодействия угрозам компьютерных атак на корпоративные автоматизированные информационные системы со стороны киберпреступников, использующих технологию Blockchain для обеспечения своей деятельности.

Выявление состава и ролей участников рынка криптовалют

Важным этапом для понимания процессов на рынке криптовалют, без которого невозможна осмысленная борьба с киберпреступностью, является определение состава и ролей его участников. Основными участниками финансового обмена являются:

- криптобиржи;
- миксеры (средства сокрытия операций);
- майнинг-пулы.

Криптовалютная биржа – это аналог биржи фиатных денег, на котором трейдеры (торговцы) могут покупать или продавать криптовалюту по курсам, установленным этой биржей [34]. Криптовалютные биржи разделяют по уровню децентрализации в зависимости от таких факторов, как:

- автоматизации процедуры контроля транзакций;

- требований к составу предоставляемых данных для подтверждения личности пользователя;

- наличия и уровня модерации пользователей.

На рис. 9 приведена классификация популярных криптобирж по уровню децентрализованности [34].

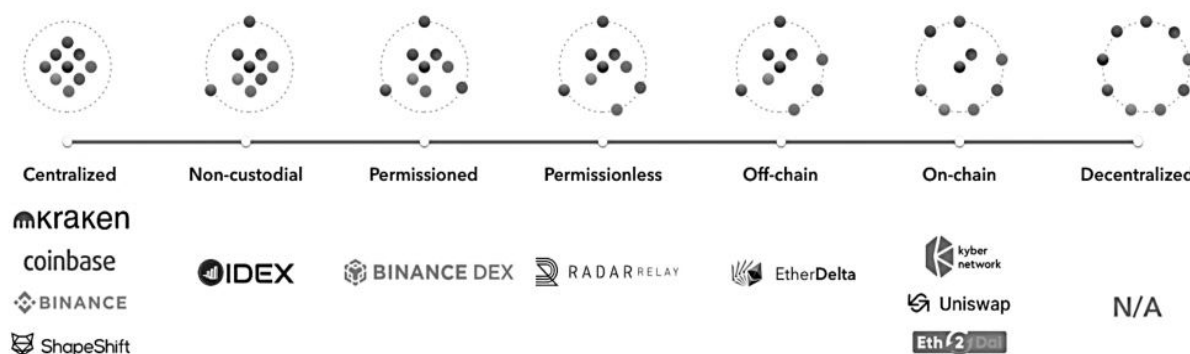


Рис. 9. Классификация популярных криптобирж по уровню децентрализации

Полностью децентрализованных криптобирж не существует, поэтому список в классификации пуст, однако данный класс субъектов потенциально несёт наибольшую угрозу для безопасности обществ и государства ввиду отсутствия эффективных механизмов влияния и контроля за их деятельностью.

Использование информационных карт позволяет визуально определить типовые структуры криптобирж. Однако, для этого помимо способностей человеческого интеллекта обрабатывать графическую информацию требуется также дополнительные сведения из сторонних ресурсов, на основании которых возможно разметить соответствующие области карты.

В качестве примера таких ресурсов можно привести сайты bitcoinabuse.com, ransomwhe.re и vivigle.com. Сайт является базой данных о злоупотреблении криптовалютами, в которой собраны все мошеннические кошельки, на которые когда-либо были поданы жалобы. Структура сайта содержит в себе распределение жалоб по типам, таким как шантаж, вымогательство, рынок «даркнета» и др.

Также на каждом мошенническом кошельке отображено количество жалоб, время публикации последней жалобы, количество криптовалюты, содержащейся на кошельке на данный момент.

Особенностью базы данных Bitcoin Abuse является встроенное API, которое позволяет выгрузить все отчеты в формате .csv, удобным для занесения его в программное средство визуализации графов Gephi.

Информационный ресурс Ransomwhere, как и Bitcoin Abuse, является краудсорсинговой площадкой, на которой каждый может разместить сведения о преступных криптокошельках. При этом сайт ransomwhe.re акцентирует внимание на платежах за вымогательство, а также осуществляет подтверждение принадлежности криптокошелька соответствующей группировке.

База данных Vivigle предоставляет возможность использовать все аспекты работы с криптовалютами – получение рейтинга кошельков, аналитику или даже оценку контрагента, даже если пользователь не зарегистрирован в системе vivigle. Самой важной особенностью ресурса является

определение держателя кошелька, будь то приватный кошелек или криптобиржа.

В настоящих исследований ресурс полезен тем, что с его помощью можно произвести разметку определенных кошельков, а это, в свою очередь, сокращает время выявления связей между узлами построенного графа и картографического определения типовых структур и разновидностей участников финансового обмена.

Получение сведений о кошельках криптобирж для выявления типовой структуры возможно с помощью ресурса walletexplorer.com, который предоставляет сведения о криптокошельках различных бирж, майнинг-пулов, сервисов, использующих Bitcoin, а также азартных игр.

Исследование Bitcoin-транзакций

Для сбора данных с этого информационного ресурса был использован парсером WebScraper, представляющим собой расширение для браузера Google Chrome.

После применения технических приемов и ресурсов дополнительных сведений, рассмотренных ранее, а именно [bitcoinabuse](http://bitcoinabuse.com), [vivilge](http://vivilge.com) и [walletexplorer](http://walletexplorer.com), а также нанесения меток в программном средстве визуализации графов Gephi и выявления связей, карта Bitcoin-транзакций за исследуемый период становится более ясной и понятной. Кластеры, ранее неизвестные, выражают некие закономерности, так как предложенная методика позволяет по нескольким отметкам определить принадлежность сразу большой группы криптокошельков к определённому типу структурного элемента на рис. 10.

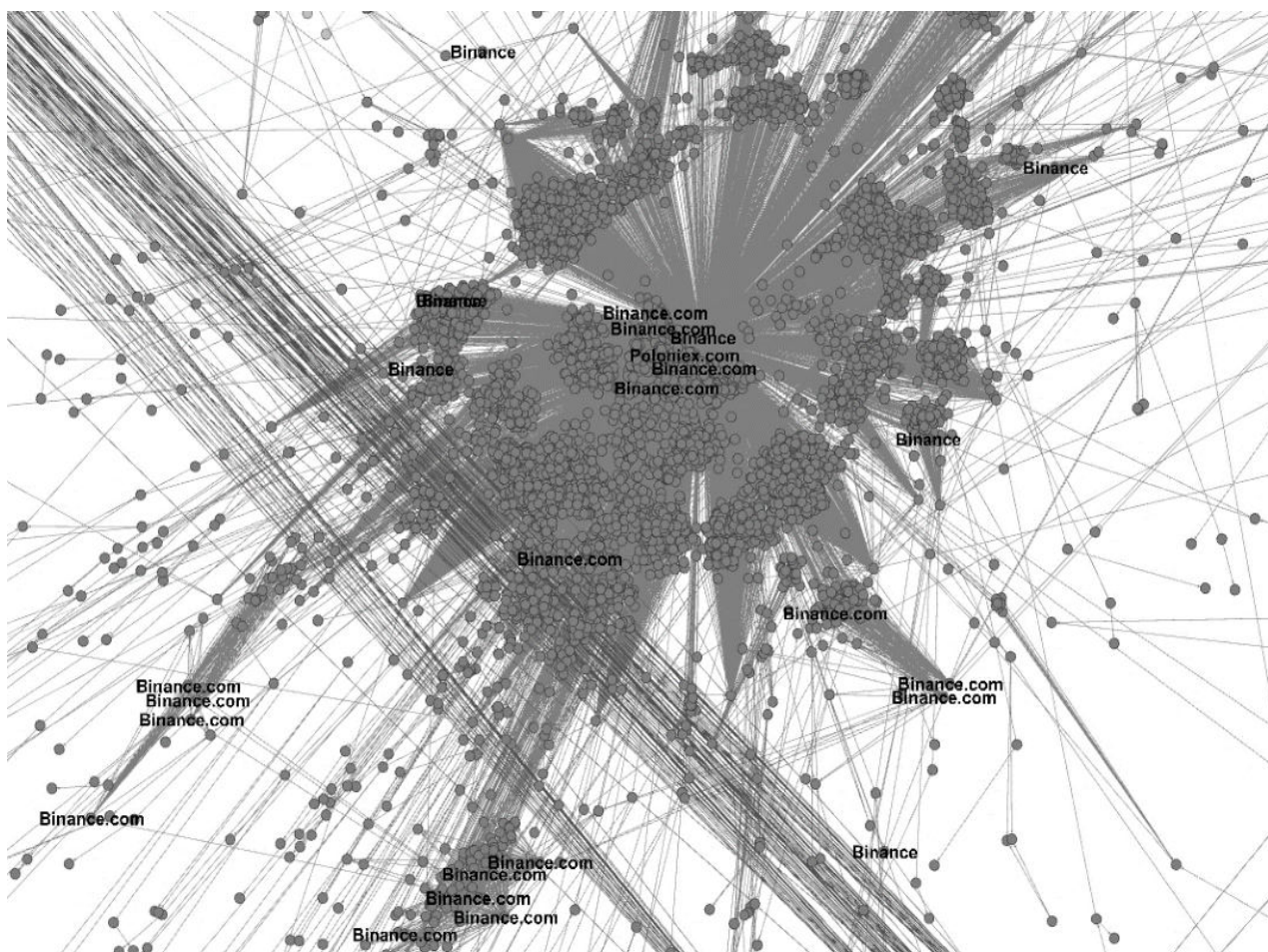


Рис. 10. Размеченная карта Bitcoin-транзакций за исследуемый период.

При детальном рассмотрении появляются обозначенные кластеры с похожей структурой «звездочки» на рис. 10. Исследовав поочередно каждую из них, можно утверждать, что с большой вероятностью данная типовая структура является подобием миксера.

Ресурс vivilge.com содержит не самые полные данные о криптобиржах и миксерах, но является достаточно достоверным источником. Доказательства выявленной закономерности представлены на рис. 11.

Также можно отметить, что в некоторых структурных элементах миксера встречались узлы кошельков криптобирж, через которые средства, подвергшиеся миксованию, отправлялись на рынок криптовалют.

С большой долей вероятности можно утверждать, что данный тип структурного элемента включает в себя подозрительные (мошеннические) узлы, которые по большей части являются новосозданными на момент совершения операций миксования, по завершении которых имеют нулевой баланс и более не используются.



Рис. 11. Структурный элемент типа «Миксер»

Такие кошельки достаточно просто выявляются в результате визуального анализа, а их исключение для процедур дальнейшего анализа (например, путём представления в виде единого узла) экономит ресурсы и разгружает внимание аналитика. При этом необходимо отметить, что все криптокошельки, связанные со структурами миксеров, должны привлекать пристальное внимание и помечаться особым образом.

Важным аспектом является то, что из огромного числа криптобирж (порядка 300) за исследуемый промежуток времени (3 часа 8 мая 2021) самыми часто встречающимися криптобижами оказались Binance и некая

неизвестная ранее и не встречающаяся в рейтинге лучших криптобирж – Btcbanker.

Оказалось, что данная биржа не имеет официального сайта, как остальные биржи, а является Telegram-ботом. В сети Интернет встречается большое количество негативных статей и отзывов по поводу данного ресурса, а также пользователи отмечают возможность вывода и обмена криптовалюты без проведения верификации личности, что говорит в пользу выбора злоумышленниками этой площадки для вывода добытых в ходе атак на корпоративные автоматизированные системы средств.

В рамках настоящего исследования было установлено, что узел, являющийся криптобиржей, представлен на информационной карте в виде узла только с входящими рёбрами (рис. 12).



Рис. 12. Пример отображения узла, входящего в структуру миксера и используемого для вывода средств

Типовая структура «Майнер» (или «Майнинг-пул») определяется как скопление узлов возле одного узла с большим количеством исходящих связей. Кроме того, адреса таких узлов содержатся в первой транзакции блока.

Майнинг-пулом называется специальный сервер, который используется для того, чтобы объединять задачи по добыче Bitcoinов или других видов цифровых активов между участниками пула, которые могут представлять, как вычислительные ресурсы обычных пользователей, так и вычислительные ресурсы крупных организаций.

После применения технических приемов и ресурсов дополнительных сведений, рассмотренных ранее, а именно walletexplorer.com совместно с парсингом с помощью Webscraper, конкретные названия майнинг-пулов были отображены в Gephi, на той же информационной карте (рис. 13).

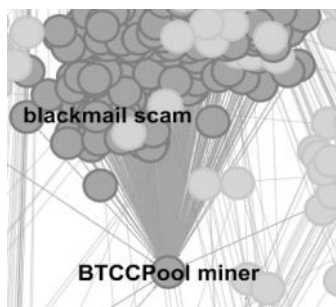


Рис. 13. Структурный элемент типа «Майнер»

При проведении исследования была замечена особенность, что во многих майнинг-пулах был узел с меткой базы данных о злоупотреблениях Bitcoin, это означает, что злоумышленник подменил адрес перевода на свой адрес, зараженный вредоносной программой подмены адресов. Следовательно, если пользователь, при совершении транзакции, вместо «здорового» узла из майнинг-пула попадает на зараженный узел злоумышленника, то эти средства остаются на подменном кошельке злоумышленника. Данная ситуация отображена на рис. 13.

Исследований Ethereum-транзакций

Как было обозначено ранее, структура транзакций со смарт – контрактами отличается от структуры Bitcoin-транзакций учетом того, что иногда поле получателя транзакции может быть пустым, если происходит создание смарт-контракта.

Отличием транзакций со смарт – контрактами от Bitcoin-транзакций является меньшая интенсивность и меньше единичных транзакций, что показано на рис. 14. Также существуют отличия между типами совершенной транзакции. Существуют три типа транзакций: call, create и transfer [6, 9, 17, 35].

При этом ресурс etherscan.io предоставляет все данные для идентификации того или иного кошелька, будь то майнинг-пул, криптобиржа или контракт. Следовательно, обращение к другим сторонним ресурсам не требуется.

Так как транзакция со смарт-контрактом может происходить и без получателя, были отобраны только те транзакции, которые имели и получателя, и отправителя. Полученный граф имеет двойную структуру, сверху отображены в основном контракты, обычные кошельки и связи между ними, а снизу отображены связанные с ними майнинг-пулы рис. 14.

В определении структурных элементов тоже существуют отличия. Например, однозначно определяется структура «майнинг-пул», как узел, имеющий только входящие связи. Для Bitcoin-транзакций такая структура определялась как криптобиржа. Не новосозданный идентифицированный смарт-контракт, наоборот, является узлом, который имеет только исходящие связи. Примеры изображений таких структур приведены на рис. 15 и 16.

Типовой структуры «миксер» в смарт-контрактах не наблюдалось на исходных данных. Это объясняется неполнотой необходимых данных или же отсутствием таковой структуры вообще.

Определение типовых механизмов поведения злоумышленников в больших объемах данных о транзакциях

Как было сказано ранее, отправной точкой в исследовании транзакций киберпреступников выступают идентификаторы принадлежащих им кошельков. Такие данные могут публиковаться как в новостных сообщениях, так и на информационных ресурсах типа Ransomware или Bitcoin Abuse. Однако достаточно часто информация о транзакциях скрыта, так как жертвы не желают раскрывать факта взлома и уплаты «выкупа». В этом случае для выявления транзакций злоумышленников могут быть использованы шаблоны их поведения на рынке криптовалют, а также косвенная информация, использование которых позволяет сократить область поиска.

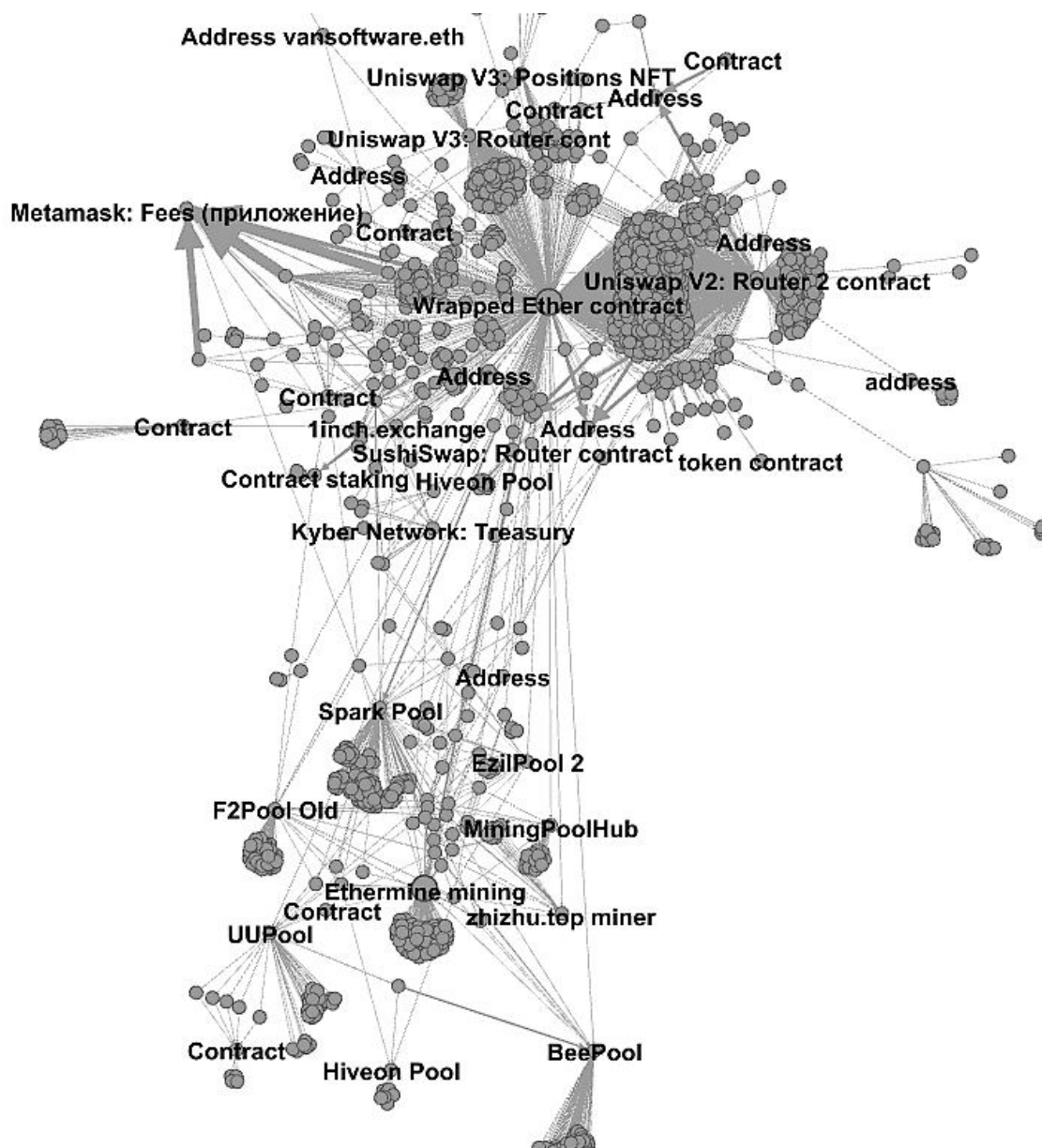


Рис. 14. Размеченная карта смарт-контрактов за исследуемый период (3 часа)

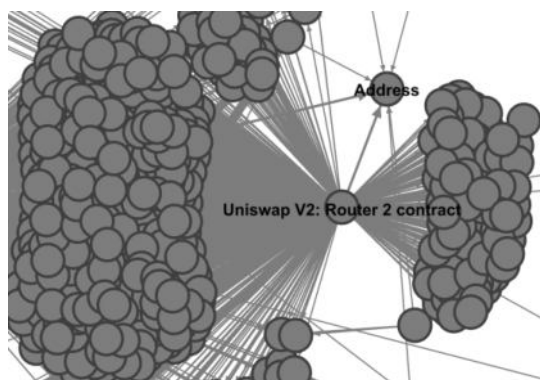


Рис. 15. Типовая структура «Смарт-контракт»

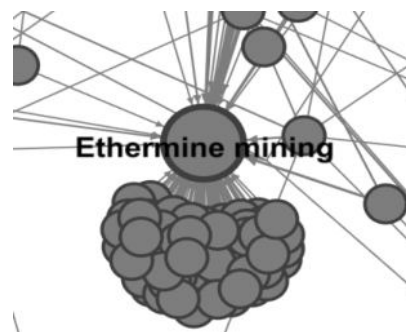


Рис. 16. Типовая структура «Майнер»

Формирование шаблонов транзакций осуществляется на основании известных случаях взлома, для которых доступна полная информация об инциденте. При его формировании важную роль играют типовые структуры, которые были рассмотрены ранее (шаблон транзакций может быть основан на выявлении узлов, связанных с миксерами и конкретными криптобиржами). Также в шаблоне должны использоваться временные характеристики цепочек транзакций (цепочка транзакций при получении выкупа для криптовалюты Bitcoin, как правило, осуществляется в пределах трёх блоков, генерируемых в течение одного часа).

Ещё одним аспектом, который должен быть учтён при формировании шаблона для поиска транзакций киберпреступников, является используемые им «обменники» для конвертирования криптовалюты. Именно поэтому важно учитывать транзакции, происходящие в Ethereum или на другой Blockchain-платформе за аналогичный промежуток времени (чтобы определить, совершались ли конвертации в другие валюты, и если да, то отследить цепочку транзакций злоумышленника).

На рис. 17 показана упрощенная схема отслеживания транзакций на абстрактных фигурах. Если криптобиржа является централизованным рынком, выявляются все трейдеры и отмечаются потенциальные подозреваемые лица, которые проводят сделки с заменой фиатных денег на криптовалюту и наоборот. Электронный кошелек (А), имеющий прямую связь с рынком, считается узлом с высокой вероятностью отмывания денег (сплошная линия), владельцем которого является первоначальное лицо, находящееся под подозрением. Подчиненные узловые кошельки (В) символизируют меньший риск (пунктирные линии), но остаются под наблюдением, если их пути пересекаются или сходятся. Если незаконный трейдер попытается проанализировать средства с биржи (как показано в кластере Г), а затем перегруппировать монеты в кошельке (Б), последний теперь становится частью расследования. Сплошные линии представляют высокую вероятность причастности к незаконной деятельности, а пунктирные линии имеют более низкий приоритет, но могут быть объединены для повышения важности.

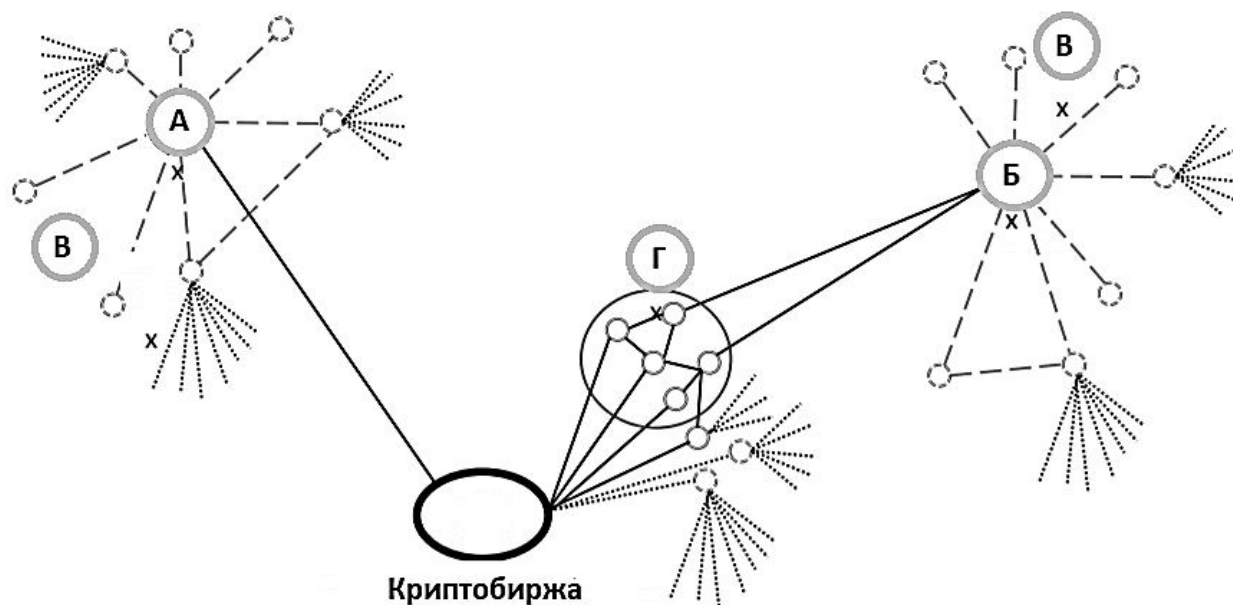


Рис. 17. Упрощенная версия возможностей отслеживания транзакций на абстрактных фигурах

Пример исследования Bitcoin-транзакций, связанных с деятельностью киберпреступной группировкой DarkSide

Атаки, проведенные группировкой DarkSide в период с 2020 по 2021 годы, представляют интерес для исследования и применения на них методики.

Негативным примером применения криптовалют злоумышленниками, интересным для исследования, представляется случай кибератаки на Colonial Pipeline – один из крупнейших топливных трубопроводов США произошедший в мае 2021 года, организованный хакерской группой DarkSide.

Атака была направлена на критически важную инфраструктуру США и явилась одной из крупнейших атак криптовымогателей [2]. В результате её проведения хакерам из DarkSide удалось парализовать работу компании Colonial Pipeline и остановить транспортировку около половины топлива, потребляемого на Восточном побережье США. Из-за этого средняя стоимость бензина в стране превысила \$3 за галлон (3,8 л), что на тот момент было максимумом с 2014 года. Размер ущерба послужил основанием уплаты компанией Colonial Pipeline выкупа в размере 75 Bitcoin (около \$5 млн).

Через несколько дней стало известно о том, что немецкая химическая компания Brenntag также подверглась саналогичной атаке и заплатила группировке вымогателей DarkSide выкуп криптовалютой Bitcoin в размере \$4,4 млн, чтобы получить инструмент для восстановления зашифрованных файлов и предотвратить публичную утечку украденных данных.

Данные инциденты наглядно показали существование проблемы борьбы с подобными киберпреступными сообществами, а также привлекли внимание общественности к опасностям неконтролируемого использования криптовалют.

С помощью разработанной системы сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах в соответствии с представленной выше методикой были проведены исследования данных инцидентов.

Исходной точкой послужил адрес кошелька злоумышленника - `bc1q7eqww9dmm9p48hx5yz5gcvmnscu65w43wfytpsfsf`, опубликованный организацией расследования киберпреступлений в Blockchain – Crystal Blockchain. На основании этой информации были выявлены блоки транзакций, относящиеся к данному адресу и собраны необходимые сведения о связанных с ними транзакциях.

В результате была сформирована информационная карта крупного масштаба, представленная на рис. 18.

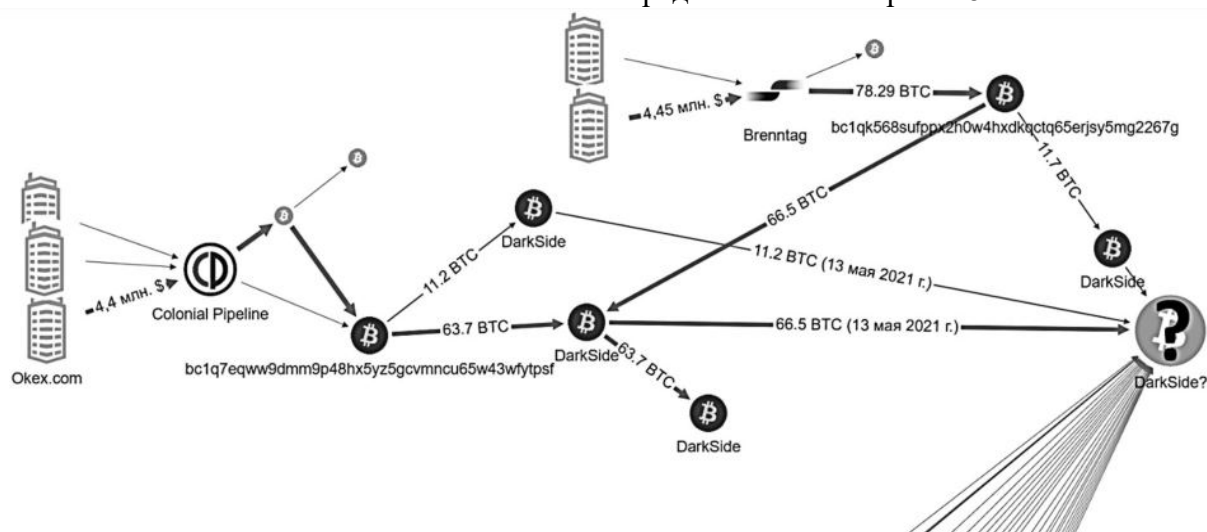


Рис. 18. Фрагмент информационной карты Bitcoin-транзакций для инцидентов с Colonial Pipeline и Brenntag

В результате анализа представленного выше фрагмента установлено, что уплаченный жертвами выкуп злоумышленники разделяли на две части в примерном отношении % 85 на % 15. Большая часть выкупа досталась так называемым «партнёрам», которые непосредственно принимали участие в атаке. Остальная доля была предназначена разработчикам криптовалюты DarkSide. Данная практика организации киберпреступных сообществ достаточно

распространена и позволяет сформировать шаблон соответствующего поведения на криптобирже Bitcoin (рис. 19).

Соотношение долей, на которые разделяется выкуп, может меняться в зависимости от договорённостей злоумышленников (как правило, от 15 % до 25 %). На основании этой информации был сформирован запрос, позволяющий получить все транзакции, удовлетворяющие данному поведению (рис. 20).

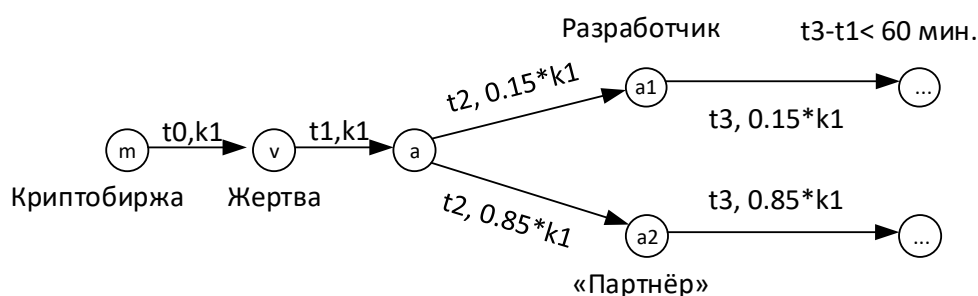


Рис. 19. Шаблон транзакций группировки DarkSide

```

1 MATCH (t:BIT_Trans) WHERE data(t.locktime)='13.05.2021' // t - транзакции от 5 мая 2021
2 MATCH (t)→(m:BIT_In_Out {tag: 'market'}) // m - кошелёк криптобиржи
3 MATCH (m)→(v:BIT_In_Out)→(a:BIT_In_Out) // v - кошелёк жертвы
4 MATCH (a)→(a1:BIT_In_Out) // a - кошелёк для уплаты выкупа
5 MATCH (a)→(a2:BIT_In_Out) WHERE (a1.in+a2.in=a.out) // a1 - кошелёк разработчика
6 AND (6*a1.in < a2.out) AND (4*a1.in > a2.out) // a2 - кошелёк "партнёра"
7 RETURN a, a1, a2

```

Рис. 20. Пример Cypher-запроса, позволяющего получить сведения о кошельках, которые удовлетворяют шаблону поведения киберпреступной группировки при получении ей выкупа от жертвы

В качестве исходных данных для выполнения данного запроса требуется наличие разметки кошельков криптобирж (tag='market'). Её нанесение осуществляется экспертом в ходе анализа карты Bitcoin-транзакций за соответствующий период с помощью описанного выше подхода обнаружения типовых структур и информационного ресурса vivigle.com (рис. 10).

Выполнение этого запроса позволяет не только выявить адреса кошельков киберпреступников, но и установить размер ущерба и состав жертв, которые подверглись атакам группировок, действия которых удовлетворяют указанному шаблону.

Оценка рисков атак киберпреступников на корпоративные информационные системы

В основе методики количественной оценки риска лежит процедура подсчёта минимального ущерба от реализации компьютерных атак криптовалюты, которая может быть выражен суммой «выкупа», уплаченного жертвой. Факт уплаты свидетельствует о том, что организация, просчитав все свои внутренние риски от потери репутации, нарушения доступности или утраты информации, считает сумму возможного ущерба большей, чем размер «выкупа», назначенный киберпреступниками.

Данную информацию возможно получить путём анализа транзакций, проводимых через Bitcoin-кошельки, так как данное средство является основным в атаках криптовымогателей на корпоративные сети. Основная сложность с их отслеживанием связана с тем, что многие жертвы стараются сохранить в тайне факт взлома своей организации, а злоумышленники используют уникальные адреса криптокошельков для каждого атакуемого объекта. Причём соответствующую информацию раскрывают только тем лицам, от которых требуется получение оплаты.

Таким образом, ущерб от деятельности конкретной киберпреступной группировки может рассчитан по формуле:

$$U = \sum_i^k t_i,$$

где t_i – размер транзакции, переведённой жертвой на криптокошелёк киберпреступника;

k – количество жертв от деятельности киберпреступной группировки.

Тогда традиционно риск можно вычислить по формуле:

$$R_{isk} = P \cdot \sum_i^k t_i.$$

В ходе исследований было установлено, что киберпреступные группировки в основном придерживаются двух стратегий:

- массового заражения;
- целенаправленной атаки.

Первая стратегия характерна для атак типа Wannycry, в результате которой эксплуатировалась уязвимость нулевого дня (BDU:2017-01099). При проведении атаки Wannycry не было четкой цели, а заражение осуществлялось для всех доступных устройств, подверженных данной уязвимости. Уплата выкупа жертвами осуществлялась на несколько Bitcoin-кошельков, которые были одинаковыми для всех жертв.

В рассмотренной ситуации с DarkSide [2] злоумышленники придерживались другой стратегии, которая предполагала целенаправленный выбор жертв, которые являлись крупными корпорациями,

способными заплатить большой выкуп. В этом случае сама атака требовала лучшей организации и скрытности.

Для данных стратегий характерны различные законы распределения вероятности P . Злоумышленники, которые занимались разработкой программного обеспечения для атаки Wannycry, не могли знать, сколько денежных средств она им принесет, ведь существует вероятность, что никто бы не заплатил, посчитав ущерб от потери информации незначительным, относительно величины выкупа. Обозначим p_1 как вероятность успешной атаки. Причем под успешной атакой понимается заражение устройства без условия получения прибыли.

Атака группировки DarkSide [2] действует по другим принципам. Атака была разработана, режиссирована и успешно реализована исключительно под конкретную корпоративную информационную систему. Так как злоумышленники знали особенности бизнес-процессов атакуемой компании, они понимали какая сумма будет приемлемой для назначения в качестве выкупа. По этой же схеме была атакована компания Brenntag. Пусть N – количество атакованных организаций, тогда в данном случае его значение будет минимальным, а вероятность p_1 – наоборот. При её расчёте уместно следующее предположение: вероятность успешности атаки зависит от масштаба атакуемой компании и не зависит от системы защиты, вероятность преодоления которой принимается равной 1 (допускается, что за достаточно продолжительное время злоумышленники уровня DarkSide всегда могут найти и взломать систему защиты наименее защищённой жертвы, способной заплатить большой выкуп). Тогда можно применить биномиальную схему.

Имеется n – атакуемых компаний, тогда риск, что k компаний заплатят выкуп равняется [36]:

$$R_{isk}(k_n) = k \cdot w_0 \cdot C_n^k p_0^k (1 - p_0)^{n-k},$$

где w_0 – вероятность ущерба одной компании;

$k \cdot w_0 = w_k$ – вероятность общего ущерба;

p_0 – вероятность заплатить одной компании, но поскольку они все однородные, у нас вытекает биномиальное распределение.

Следовательно, средний риск будет равен математическому ожиданию биномиального распределения:

$$\frac{R_{isk}(k)}{R_{isk}} = w_0 \cdot n \cdot p_0.$$

Но модели такого типа уже рассматривались в том числе и на нашей кафедре, и потеряли свою актуальность. Хотя модель такого типа вполне способна решить конкретную ситуацию в заранее обозначенных рамках, границах и условиях.

Для учёта разного вида атак, нужно считать, что p_0 – разное и связывать с какими-то параметрами и характеристиками определенной компании.

Если p_k разное, то ситуация сильно осложняется, это будет обобщение биномиального распределения и для вычисления этой вероятности требуется весьма объемная формула.

Разберем два случая:

- все элементы одинаковые;
- все элементы разные.

В первом случае в формуле Бернулли все произведения будут одинаковыми, и считаются просто коэффициентом, а во втором – все произведения разные и необходимо учитывать все комбинации, которые могут возникнуть. Этот нюанс возможно обойти через производящую функцию, но в итоге, все придет к тому же самому, при вычислении вручную. Этот вопрос можно решить через запрограммированные функции, что позволит получить качественные результаты, но этот процесс также потребует затраты времени и выходит за рамки настоящего исследования.

Поэтому придется делать определенные обобщения, например, с разными вероятностями или оборотом компании. Нужно расположить компании в ряд по оборотам (по нарастанию) и считать p_k пропорциональным обороту из-за невозможности посчитать обороты линейно. То есть необязательно, чтобы обороты возрастали пропорционально номеру

компании, поэтому такая связь тоже не даст необходимого результата.

Если мы считаем, что атака может быть, как успешная, так и неуспешная, и если она успешная, то возможно заплатят и не заплатят.

Вероятность того, что k заплатят, при условии, что n – атак успешных прошло, составит:

$$C_n^k p_0^k (1 - p_0)^{n-k} = p_k = p\left(\frac{k}{n}\right).$$

Но также допустим, что всего делается N атак, и какова вероятность того, что n будет успешных.

Обозначим вероятность успешной атаки p_1 .

Если она независима, то тоже получается биномиальное распределение, но с учетом p_1 , можно пользоваться законом редких явлений Пуассона.

При $p_1 < 0,1$, имеем:

$$p(n) = \frac{(N \cdot p_1)^n}{n!} \cdot e^{-N \cdot p_1}.$$

Тогда по формуле полной вероятности, мы получаем:

$$p(k) = \sum_{n=0}^N p(n) \cdot p\left(\frac{k}{n}\right),$$

$$p\left(\frac{k}{n}\right) = C_n^k p_0^k (1 - p_0)^{n-k}.$$

Следовательно, риск можно вычислить по следующей формуле:

$$R_{isk}(W_k) = k \cdot W_0 \cdot p(k) =$$

$$= \frac{k W_0 e^{-N \cdot p_1} p_0^k}{q_0^k} \cdot \sum_{n=k}^{\infty} \frac{1}{n!} \cdot C_n^k (N p_1 q_0)^n.$$

В результате получается распределение Пуассона, что нормально из биномиального распределения, и тогда получается:

$$\frac{k W_0 (N p_1 q_0 p_0)^k}{k! q_0^k} \cdot e^{-N p_1 p_0}.$$

В итоге приходим к Пуассоновскому распределению, что не является

неожиданностью, ведь когда Биномиальное распределение скрещивается с Пуассоновским, получается Пуассоновское.

Единственное отличие, что в обычном Пуассоновском распределении значение p_0 должно быть маленькое. В нашем случае вероятность заплатить p_1 скорее всего будет маленькой, ведь такой вид атаки рассчитан на большой охват, но на маленькую вероятность успеха, даже с условием хорошей подготовки. К такому типу атак как раз подойдет атака Wannycry.

В итоге получается первое возможное обобщение, и первое значение риска:

$$R_{isk}(W_k) = \frac{k W_0 \cdot (N p_1 p_0)^k}{k!} \cdot e^{-N p_1 p_0}.$$

Также для разных случаев возможен и другой вариант через производящие функции. Но использование k -й производной не совсем удобно, так как существует сложность определения p_k для разных компаний. Значение p_0 возможно выбрать из статистики, например, количество финансовых потерь определенного числа компаний в среднем. Также значение p_1 возможно оценить по разным критериям успешной атаки, например количество ущерба, скорость принятия решений, цена компании на рынке и т.д.

Но, первое обобщение, а именно закон редких явлений, также требует большого значения N , тогда он будет работать как полагается.

Перейдем ко второму обобщению. Как уже было отмечено, пуассоновский и биномиальный законы распределения, хорошо взаимодействуют друг с другом и сворачиваются в формулу, которую удобно будет применять на практике. В случае, если бы вышло два биномиальных закона, то при их объединении формула была бы слабо применима в решении практических задач.

Первое обобщение относится к первому варианту атак, это массовые атаки, их характеризует больше значение N – атакуемых устройств, но маленькое значение p_1 , что означает маленькую вероятность пробития.

$$P(n) = C_N^n \cdot p_1^n \cdot q_1^{N-n},$$

где p_1 – не будет маленьким, но и N не будет большим, так как происходит подготовленная атака на маленькое число жертв.

Второй вариант, это редкие атаки, но с высокой вероятностью поражения.

$$P(k) = C_N^k ((p_1 q_0 + q_1)^{N-k} (p_1 p_0)^k).$$

В формуле 15 получается биномиальное распределение с нестандартными параметрами. Что является вторым вариантом атак, которые характеризуются маленьким значением N , но большим p_1 .

Значение риска применяя второе обобщение будет следующее:

$$R_{isk}(W_k) = k W_0 C_N^k ((p_1 q_0 + q_1)^{N-k} (p_1 p_0)^k).$$

Рекомендации и возможные меры снижения рисков

Зная возможные шаблоны атак, схемы работы кибергруппировок, и определенные особенности технологии Blockchain, становится возможным выработать рекомендации по снижению рисков атак вида программ – вымогателей.

Анализ связан с расчётом общего риска. Ведь обычному пользователю, который подвергся атаке криптовымогателей, не особо будет интересоваться рисками, ему важно вернуть доступ к данным, которые он потерял, которые были зашифрованы в результате атаки на его устройство. Либо же, сохранность и нераспространение данных, которые были у него украдены.

Необходимость в оценке рисков появляется, когда рассматриваются ресурсы организации или государства на те или иные механизмы защиты. Если риски будут большими, то на эту угрозу необходимо уделять больше внимания, а если маленькие, то соответственно меньше.

1. Рекомендацией, которая вытекает из особенностей работы программ – вымогателей, а именно, шифрование данных, будет создание резервных копий данных. В случае проведения успешной атаки, данные, которые были зашифрованы программами - шифровальщиками, смогут быть быстро восстановлены, не нанося финансовых ущербов компании, и повышая общий уровень кибербезопасности. При этом, как

показывает практика, наличие только лишь резервных копий недостаточно. Требуется чёткое понимание реального времени развёртывания системы из резервных копий с учётом возможных остановок бизнес-процессов.

2. Следующая рекомендация больше подойдет для больших информационных автоматизированных систем, это децентрализация данных и самой системы, чтобы кибератака на ключевую её часть не парализовала всю систему целиком. Когда управление всей системой идет из единого центра, атака на него выведет из строя большую часть информационной сети, что повлечет за собой большой ущерб, как финансовый, так и репутационный.

3. Декомпозиция данных в автоматизированной информационной системе, как большой, так и маленькой. Разбиение большого, на что-то поменьше даст возможности минимизировать ущербы от компьютерной атаки, ведь существенно уменьшается вероятность потерять большой объем данных. При просчете ущербов от уже проведенной атаки, с большей вероятностью, ущерб от утерянных данных окажется куда меньше, чем ущерб от выплаты злоумышленникам.

4. Анализ успешных кибератак на автоматизированные информационные системы смежных областей деятельности или схожих по структуре (анализ слабых мест подобных систем). Данный вид знаний дает компании возможность управлять рисками успешных атак на их систему, рассчитывая и осознавая возможные ущербы от реализации той или иной атаки на разные сектора автоматизированной информационной системы.

5. Регулярные обновления ПО для минимизации возможности эксплуатации уязвимости при совершении противоправных действий.

Однако в данной работе киберпреступность рассматривается на более высоком уровне её организации и масштаба, на которые она и вышла за последние годы. Если раньше использовались наличные деньги и банковские переводы, которые более прозрачны для правоохранительной системы, то с появлением криптовалют, у них

злоумышленников появился новый механизм, когда киберпреступность смогла организовываться в транснациональные сообщества и стало не особо важно, где находится преступник. Программист может находиться в одной стране, жертва в другой, а заказчик в третьей, а сервера инфраструктуры, обеспечивающей коммуникацию между ними, в четвертой стране. Такая угроза приобрела актуальность в последние годы и носит уже массовый характер. Для защиты от таких угроз действенными мерами являются:

6. Усиление контроля над криптобиржами, что обеспечивается блокировкой криптобирж, которые были замечены в посредничестве с криптовымогателями, помощи в обналичивании средств, полученных незаконным путем. Криптобиржи, которые отказываются сотрудничать с государством, и предоставлять сведения о владельцах, определенных криптокошельков, сильно затрудняют и усложняют процесс поимки злоумышленников и возврат причиненного ущерба от деятельности киберпреступной группировки. Действия в этом направлении активно ведутся, так, например, США усиливает контроль за криптовалютой и криптобиржами [3].

7. Использование сервисов и подобных системе, разработанной в рамках настоящих исследований. Данные средства позволяют не только расследовать преступления, но и рассчитывать риски от подобных угроз для более эффективного планирования расходов на обеспечение защиты информации. Их использование должно позволять проводить анализ как можно большего состава криптовалют для различных Blockchain-платформ. Это обусловлено тем, что злоумышленники для сокрытия своих транзакций могут переводить полученную незаконным путем криптовалюту из одной Blockchain-платформы в другую, усложняя расследование таких преступлений.

Заключение

Таким образом, в рамках проведенных исследований были разработаны программно-технические средства и предложены методики, позволяющие

оказывать противодействие киберпреступным группировкам, использующим в своей деятельности Blockchain-технологии.

Разработанная система сбора и картографического анализа сведений о Bitcoin-транзакциях и смарт-контрактах является комплексным решением, посредством которого могут быть объединены усилия аналитиков, занимающихся расследованием компьютерных преступлений, совершаемых с использованием платформ Bitcoin и Ethereum. Её отличие от существующих аналогов заключается в используемом составе программных решений, которые обеспечивают:

- возможностью масштабирования и расширения функционала (в том числе за счёт разработки дополнительных модулей сбора для других Blockchain-платформ);

- быстрое развёртывание аналитических инструментов на базе серверов под управлением операционных систем семейства Windows и Linux.

В результате решения задачи разработки методики построения и анализа карт Blockchain-транзакций и смарт-контрактов была выявлена система сложных взаимоотношений в рамках обмена криптовалютами. Определены участники такого обмена, сформулированы правила построения и анализа карт биткоин-транзакций и смарт-контрактов, в том числе:

- правила построения информационных карт Blockchain-транзакций;

- правила визуального обнаружения участников Blockchain-платформ;

- правила формирования шаблонов типового поведения субъектов Blockchain-транзакций.

Были определены источники дополнительных сведений (в том числе bitcoinabuse.com, ransomwhe.re и vivigle.com и walletexplorer.com), необходимые для нанесения разметки на соответствующие информационные карты, для проведения картографического анализа. Также были отмечены отличительные аспекты применения методики к смарт-контрактам.

Впервые была предложена методика оценки рисков атак киберпреступников на

корпоративные информационные системы, основанная на расчёте минимального значения ущербов, нанесённых организациям криптовымогателями.

Для демонстрации возможностей разработанного методического и инструментального обеспечения был проведён анализ транзакций, осуществлённых DarkSide в ходе атак, совершённых в мае 2021 года. В результате был определён шаблон транзакций, типичных для столь высокоорганизованных группировок криптовымогателей.

По итогам исследования были предложены рекомендации по снижению рисков от данной преступной деятельности. Рекомендации учитывают два вида стратегий криптовымогателей («массового заражения» и «целенаправленных атак»), для которых характерны различные варианты расчета рисков.

В рамках развития полученных результатов перспективными направлениями видятся исследования других Blockchain-платформ, как в контексте использования их киберпреступниками (например, исследование транзакций платформы Monero, активно используемой киберпреступниками), так и в качестве инструмента защиты, позволяющего обеспечить достоверность и автономность автоматизируемых процессов и систем (в том числе, систем взаимодействия IoT-устройств или процедур проведения открытого голосования с использованием технологии Blockchain).

Настоящую статью не следует рассматривать как еще один вариант практического приложения традиционной картографии, успешно используемой в топографии, экономике и других отраслях науки и техники. В ней был продемонстрирован принципиально новый, актуальный подход к интеграции и развитию знаний разнообразных дисциплин (теория сетей, машинное обучение, управления рисками и так далее) с прямой ориентацией эффекта в наглядной глубокой аналитике обеспечения информационной безопасности остро нуждающегося сейчас в защите глобального, национального и регионального киберпространства. Вниманию читателя

предлагается методически и программно-технически отработанный инструментарий технологической поддержки лицу, принимающему решения в стремительно ожесточающемся цифровом пространстве [1-2, 5-8].

В этом случае карты, обладающие на порядок более высокой инфоёмкостью (в сравнении с вербальным представлением и наглядностью, позволяют выявить скрытые принципиально важные причинно-следственные связи субъектов, объектов и процессов реализации кибератак, а также выработать меры противодействия им.

Список литературы

1. Satoshi Nakamoto. Bitcoin: A Peer-to-Peer Electronic Cash System. Режим доступа: <https://bitcoin.org/bitcoin.pdf>. (дата обращения: 15.06.2021)
2. Эксперты отследили биткойн-кошелек группировки DarkSide. Режим доступа: <https://www.securitylab.ru/news/520320.php>. (дата обращения: 15.06.2021)
3. Минюст США приравнял расследования атак вымогательского ПО к расследованиям терроризма. Режим доступа: <https://www.securitylab.ru/news/520896.php>. (дата обращения: 15.06.2021)
4. Байден заявил о предложении Путину защитить 16 секторов от кибератак. Режим доступа: <https://www.rbc.ru/politics/16/06/2021/60ca35199a7947191c7a646d>. (дата обращения: 15.06.2021)
5. An Abnormal Transaction Detection Mechanim on Bitcoin. Режим доступа: <https://ieeexplore.ieee.org/abstract/document/9027529>. (дата обращения: 15.06.2021)
6. Deanonymisation in Ethereum Using Existing Methods for Bitcoin. Режим доступа: https://www.os3.nl/_media/20172018/courses/rp1/p61_report.pdf. (дата обращения: 16.06.2021)
7. Clustering Blockchain Data. Режим доступа: https://link.springer.com/chapter/10.1007/978-3-319-97864-2_3. (дата обращения: 15.06.2021)
8. Quantitative analysis of cryptocurrencies transaction graph. Режим доступа: <https://appliednetsci.springeropen.com/articles/10.1007/s41109-019-0249-6>. (дата обращения: 18.06.2021)
9. Exploring Ethereum's Blockchain Anonymity Using Smart Contract Code Attribution. Режим доступа: <https://ieeexplore.ieee.org/abstract/document/9012681>. (дата обращения: 18.06.2021)
10. Data-driven analysis of Bitcoin properties: exploiting the users graph. Режим доступа: <https://link.springer.com/article/10.1007/s41060-017-0074-x>. (дата обращения: 18.06.2021)
11. D. Dupuis, K. Gleason. Money laundering with cryptocurrency: open doors and the regulatory dialectic. Режим доступа: <https://www.emerald.com/insight/content/doi/10.1108/JFC-06-2020-0113/full/html>.
12. C. Zhao, Y. Guan. A graph-based investigation of bitcoin transactions. Режим доступа: https://link.springer.com/chapter/10.1007/978-3-319-24123-4_5. (дата обращения: 18.06.2021)
13. BitIodine: Extracting Intelligence from the Bitcoin Network. Режим доступа: https://www.researchgate.net/publication/290737633_BitIodine_Extracting_Intelligence_from_the_Bitcoin_Network. (дата обращения: 18.06.2021)
14. The price of anonymity: empirical evidence from a market for Bitcoin anonymization. Режим доступа: <https://academic.oup.com/cybersecurity/article/3/2/127/4057584> - Текст: электронный. (дата обращения: 20.06.2021)
15. Nakamoto S. The Genesis Block: The Proof of Work / Satoshi Nakamoto - Benjamin Capital Management Group Incorporated / dba/Satoshi Nakamoto, 2018. - 504 с.: ил. (дата обращения: 20.06.2021)
16. Swan M. Blockchain: Blueprint for a New Economy / Melanie Swan. – O'Reilly Media, 2015. – 152 с.
17. Башир. И. Блокчейн. Архитектура, криптовалюты, инструменты разработки, смарт-контракты / Имран Башир. – ДМК Пресс, 2019. – 538 с.
18. Narayanan A. Bitcoin and Cryptocurrency Technologies: A

- Comprehensive Introduction / A. Narayanan [и др.]. Princeton University Press, 2016 – 336 с.
19. Калашников А.О. Картографический подход в библиометрическом исследовании отечественных научных школ, сложившихся в области защиты информации и обеспечения информационной безопасности / А.О. Калашников, А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2019. Т. 22. № 4. С. 455—484.
20. Michael Fleder. Bitcoin Transaction Graph Analysis. URL : <http://arxiv.org/abs/1502.01657> (дата обращения: 22.06.2021)
21. Elli Androulaki Evaluating User Privacy in Bitcoin. Financial Cryptography and Data Security. Ed. by Ahmad-Reza Sadeghi. Lecture Notes in Computer Science. Springer Berlin Heidelberg, 2013, 34 - 51 с.
22. M. Harrigan. The Unreasonable Effectiveness of Address Clustering, 2016 Internet of People, and Smart World Congress, 368 - 373 с.
23. Massimo Bartoletti A General Framework for Blockchain Analytics. Proceedings of the 1st Workshop on Scalable and Resilient Infrastructures for Distributed Ledgers. – URL : <http://blockchain.unica.it/projects/blockchain-analytics>. (дата обращения: 23.06.2021)
24. Татьяна Б, Денис Л. / Кибер риски и зачем их оценивать методика «Deloitte» // Количественная оценка киберрисков 2020 г - 8 с.
25. Bitcoin Risk Analysis. / Mariam Kiran – School of Electrical Engineering & Computer Science, University of Bradford, 2014. – 28 p.
26. Остапенко О.А. Методология оценки риска и защищенности систем / О.А. Остапенко // Информация и безопасность. 2005. Т. 8. № 8. С. 28.
27. Остапенко Г.А. Управление информационными рисками распределенных систем: актуальные направления исследований / Г.А. Остапенко, В.И. Борисов // Системы управления и информационные технологии. 2011. Т. 43. № 1.1. С. 163—167.
28. Остапенко Г.А. Риски распределенных систем: методики и алгоритмы оценки и управления / Г.А. Остапенко, Д.О. Карпеев, Д.Г. Плотников, Р.В. Батищев, И.В. Гончаров, П.А. Маслихов, Е.А. Мешкова, Н.М. Морозова, С.А. Рязанов, С.В. Субботина, В.А. Транин // Информация и безопасность. 2010. Т. 13. № 4. С. 485 — 530.
29. Аникин, И.В. Метод оценки внутренних рисков информационной безопасности корпоративных информационных сетей / И.В. Аникин // Информация и безопасность. 2014. Т. 17 №2. С. 320-323.
30. Malte Moser and Rainer Bohme. The price of anonymity: empirical evidence from a market for Bitcoin anonymization"Financial Cryptography and Data Security. 127 с. – Электрон. дан. Режим доступа:<https://academic.oup.com/cybersecurity/article/3/2/127/4057584>. (дата обращения: 26.06.2021)
31. An analysis of Bitcoin OP RETURN metadata – Электрон. дан. Режим доступа:<https://arxiv.org/pdf/1702.01024.pdf>. (дата обращения: 26.06.2021)
32. Jacomy M. ForceAtlas2, A graph Layout Algorithm For Hady Network Vizualization / M. Jacomy, S. Heymann // The Mathematica Journal. 2012. 22 с.
33. Сердечный А.Л. Подход картографического исследования рисков защищаемого киберпространства / А.Л. Сердечный // Информация и безопасность. 2020. Т. 18. № 1. С. 5—19.
34. How Decentralized are DEXs? A Classification System for Decentralized Exchanges. - Электрон. дан. Режим доступа:<https://medium.com/totle/how-decentralized-are-dexs-a-classification-system-for-decentralized-exchanges-5f06fb7564e6>. (дата обращения: 5.07.2021)
35. Формула Бернулли. URL: <http://mathhelpplanet.com/static.php?p=povtornye-nezavisimye-ispyt>. (дата обращения: 10.07.2021)

Государственный научно-исследовательский испытательный институт
проблем технической защиты информации ФСТЭК России
State science research experimental institute of technical information protection
problem of Federal service of technical an export control

Воронежский государственный технический университет
Voronezh State Technical University

Поступила в редакцию 20.07.2021

Информация об авторах

Сердечный Алексей Леонидович – канд. техн. наук, начальник лаборатории, Государственный научно-исследовательский испытательный институт проблем технической защиты информации ФСТЭК России, e-mail: alex-voronezh@mail.ru

Скогорева Дарья Андреевна – студент, Воронежский государственный технический университет, e-mail: skog.d@mail.ru

Длинный Евгений Павлович – студент, Воронежский государственный технический университет, e-mail: dlin@mail.ru

Ле Тиен Чинь – студент, Воронежский государственный технический университет, e-mail: letch@mail.ru

Чьеу Динь Вьет – студент, Воронежский государственный технический университет, e-mail: chet @mail.ru

CARTOGRAPHIC STUDY OF BLOCKCHAIN TRANSACTIONS AND SMART CONTRACTS OF CYBERCRIMINALS IN THE CONTEXT OF IMPLEMENTING ATTACKS ON AUTOMATED INFORMATION SYSTEMS AND ASSESSING THE DAMAGE TO THEIR IMPLEMENTATION

A.L. Serdechnyy, D.A. Skogoreva, E.P. Dlinnyy, T.Ch. Le, D.V. Cheu

The purpose of this study should be considered to counteract computer crime by improving the methods of analyzing their financial transactions carried out as part of operations with cryptocurrencies built on Blockchain technology. As part of the research, a software system for collecting and cartographic analysis of information about Bitcoin transactions and smart contracts has been developed, and a methodology for its application has been developed to solve problems related to countering computer crime. Using the example of the analysis of the activities of crypto ransomware, the possibility of using the methodology to assess the risks associated with the corresponding threats is shown. Based on the estimates obtained, recommendations were developed to reduce the risks from the threats of the impact of ransomware. The obtained results can be applied to counteract computer crimes on corporate information systems, as well as to assess the risks of implementing other threats associated with groups using cryptocurrencies to carry out their criminal activities.

Keywords: cartographic method, Blockchain, smart contracts, bitcoin, ransomware, risk, damage.

Submitted 20.07.2021

Information about the authors

Alexey L. Serdechnyy – Cand. Sc. (Technical), Chief of Laboratory, State science research experimental institute of technical information protection problem of Federal service of technical an export control, e-mail: alex-voronezh@mail.ru

Darya A. Skogoreva – student, Voronezh State Technical University, e-mail: skog.d@mail.ru

Eugene P. Dlinnyy – student, Voronezh State Technical University, e-mail: dlin@mail.ru

Tien Chin Le – student, Voronezh State Technical University, e-mail: letch@mail.ru

Dinh Viet Cheu – student, Voronezh State Technical University, e-mail: chet @mail.ru